

Attack. Persist. Exfiltrate. Repeat

Nathan Hutchinson

Steve Simmons



THANK YOU TO OUR SPONSORS



#SCS2025

Nathan Hutchinson

Microsoft Solutions Architect @
Threatscape

Microsoft
Security
MVP



Experts
Live UK
Organiser

Blog
YouTube
Podcast



#SCS2025

Steve Simmons

Azure Solutions Architect @
Air IT Group

Hak5
payload
winner



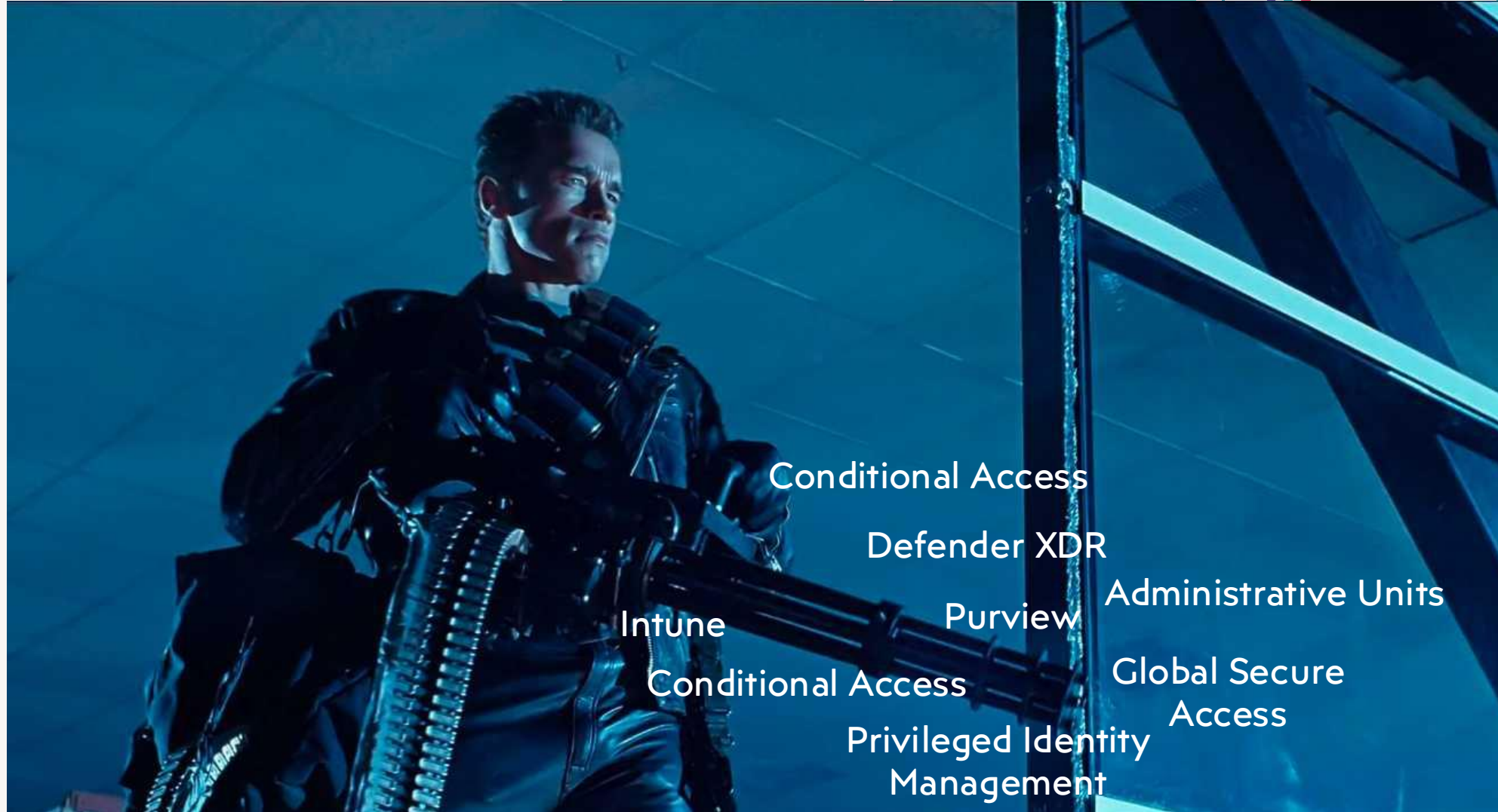
Wi-Fi
hacking
enthusiast

DefCon
Black
Badge

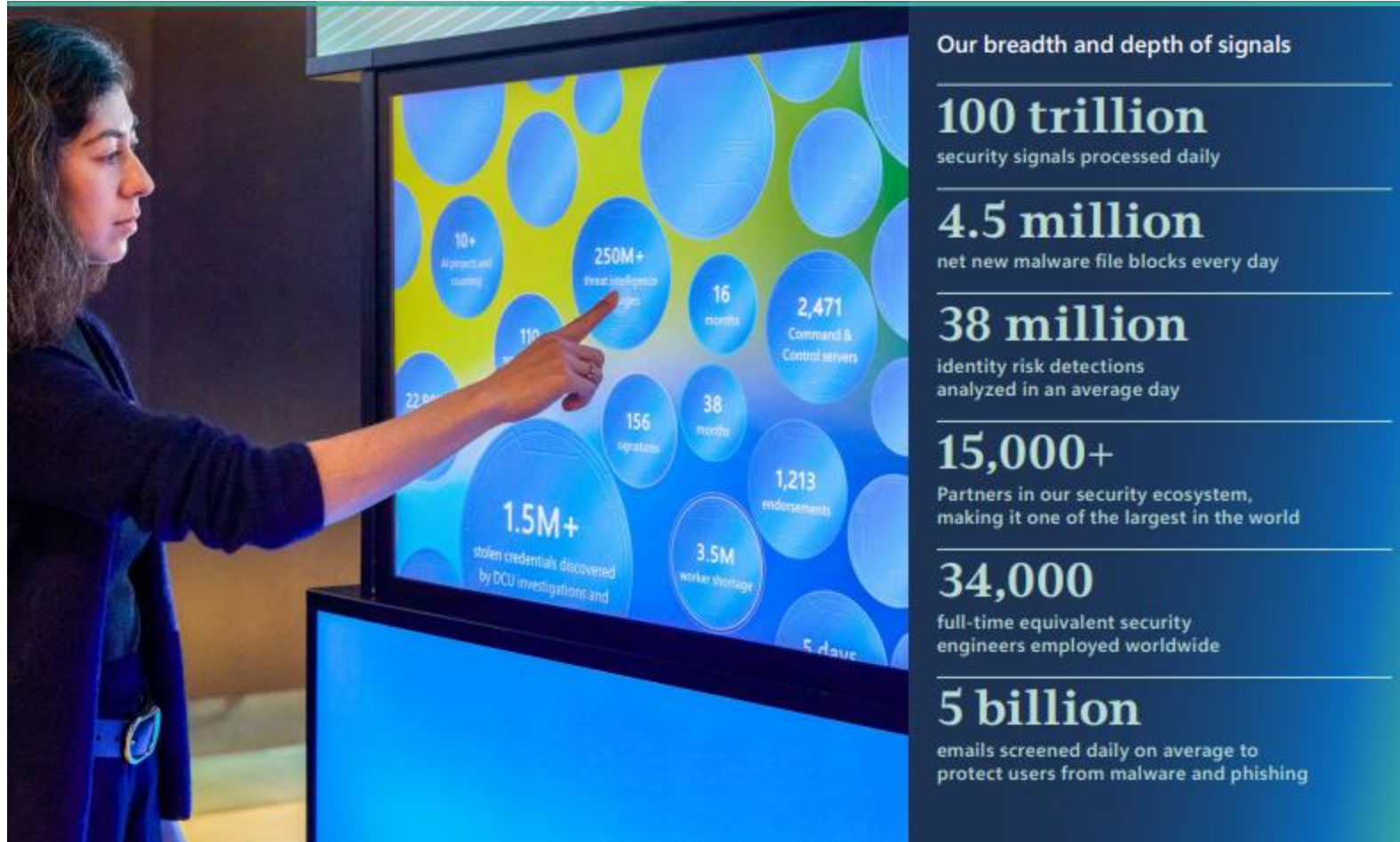


#SCS2025

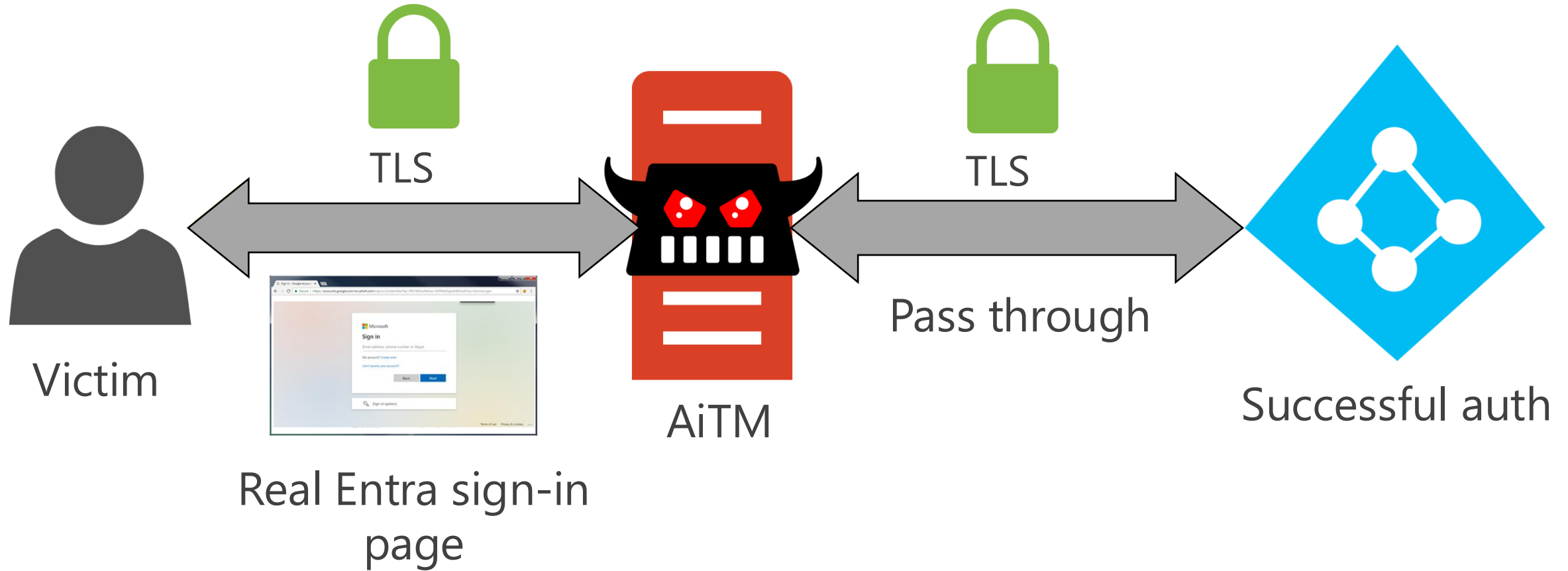
Agenda



Microsoft's Unique Vantage Point



#SCS2025





steve@Slytherin-PC: ~



steve@Slytherin-PC: ~/Desktop/bobber

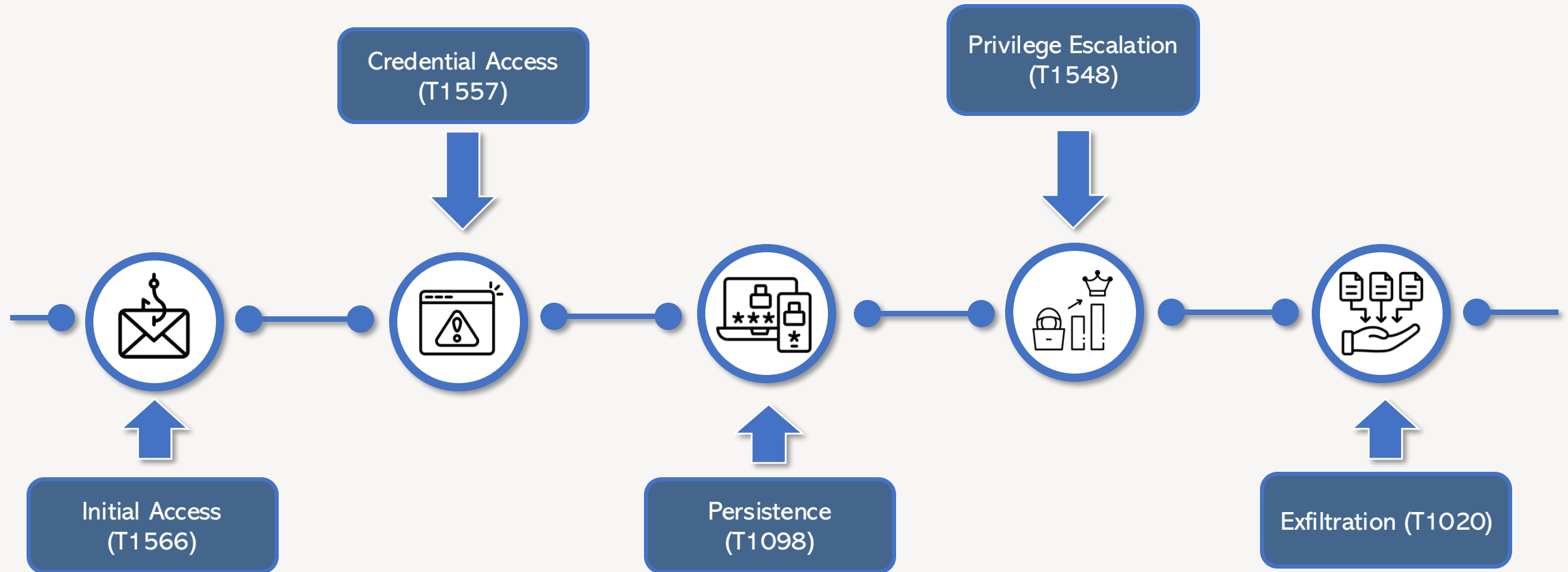


```
steve@Slytherin-PC:~$ ssh steve@evilginx.deatheaters.uk
```

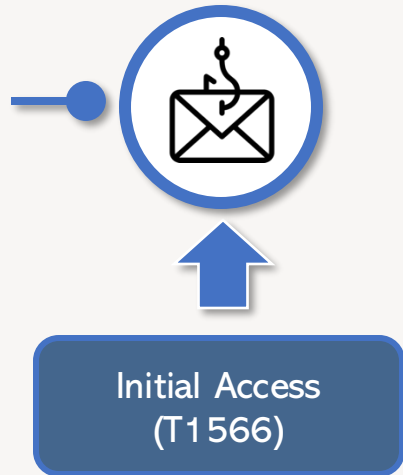


```
steve@Slytherin-PC:~/Desktop/bobber$ python3 bobber.py "/home/steve/.evilginx/data.db" --username steve --host evilginx.deatheaters.uk --all
```


The Attack



Initial Access / Phishing (T1566)



Teams – Domain Whitelisting

Choose which external domains your users have access to:

✓ Allow all external domains

Teams accounts not managed by an organization

People in my organization can communicate with Teams users who

☒ On

✓ External users with Teams accounts not managed by an organization can contact users in my organization.



Choose which external domains your users have access to:

✓ Allow only specific external domains

+ Add a domain ✕ Remove | 2 items

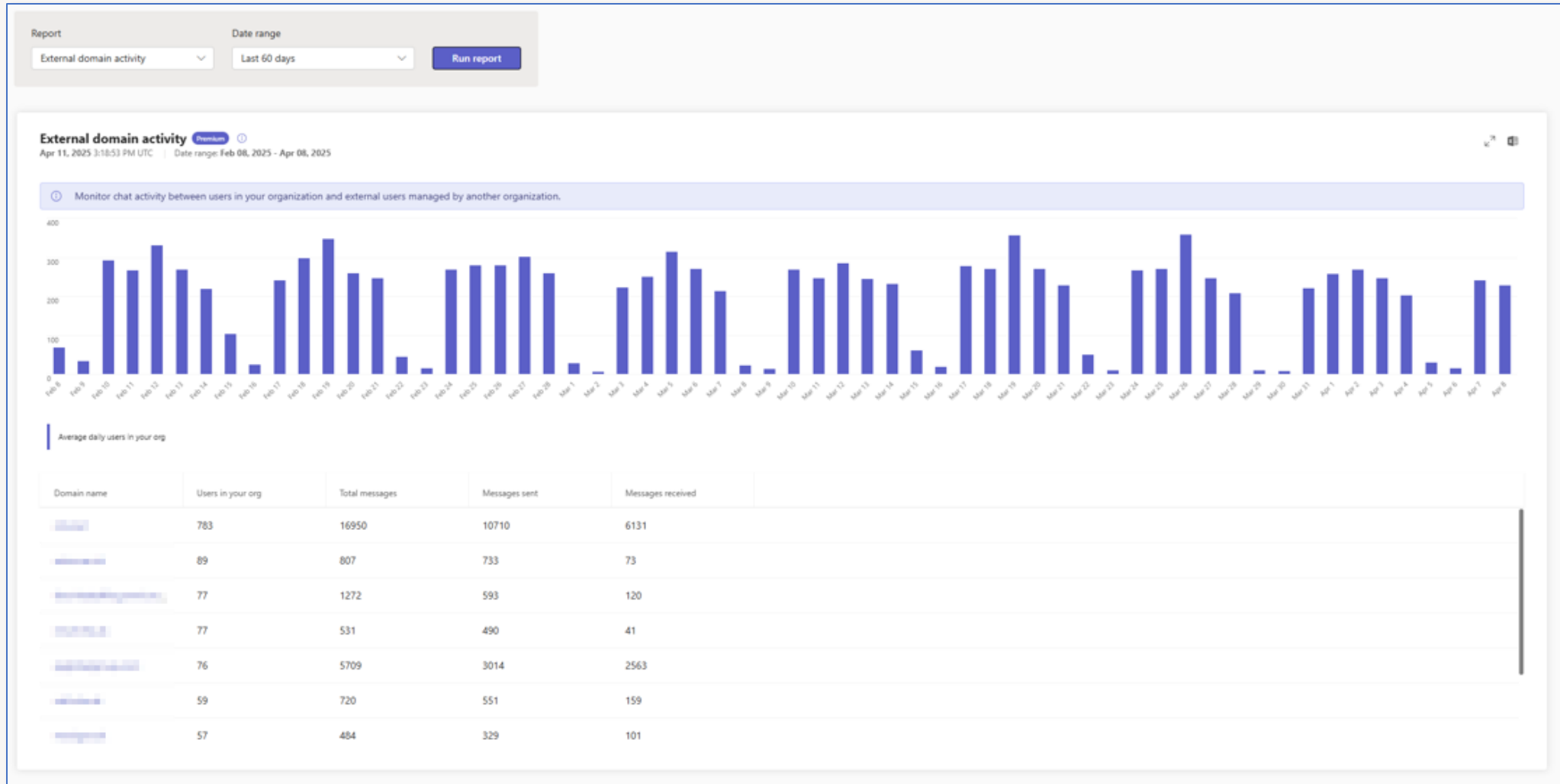


Allowed domains

ministryofmagic.co.uk

gringotts.com

Teams – Domain Whitelisting



Teams – Domain Whitelisting

To: Minerva.McGonagall@hogwartsschoolofwitchcraftandwizardry.co.uk

We can't set up the conversation because your organisations are not set up to talk to each other.

Teams – Disable External / Personal account communication

Teams accounts not managed by an organization

People in my organization can communicate with Teams users whose accounts aren't managed by an organization. [Learn more](#)

 On

☐ External users with Teams accounts not managed by an organization can contact users in my organization.



Defender for Office 365 – Safe Links

Policies & rules > Threat policies > Create safe links policy

- ☒ Narrow
- ☒ Use
- ☒ URL pro
- ☐ Not

Email

- ☒ On: Safe Links checks a list of known, malicious links when users click links in email. URLs are rewritten by default.

- ☒ A
- ☒ A
- ☒
- ☐ D

Office 365 Apps

- ☒ On: Safe Links checks a list of known, malicious links when users click links in Microsoft Office apps. URLs are not rewritten.

Teams – Zero-Hour Auto Purge (ZAP)

Settings > Email & collaboration

User reported settings

User tags

Priority account protection

Microsoft Teams protection

Microsoft Teams protection

Zero-hour auto purge (ZAP)

Protect Teams chats and channels using retroactive content scanning and removal. [Learn more about ZAP](#)

☒ On (Default)

Quarantine policies

Apply these quarantine policies to content that ZAP has removed. [Learn more about quarantine policies](#)

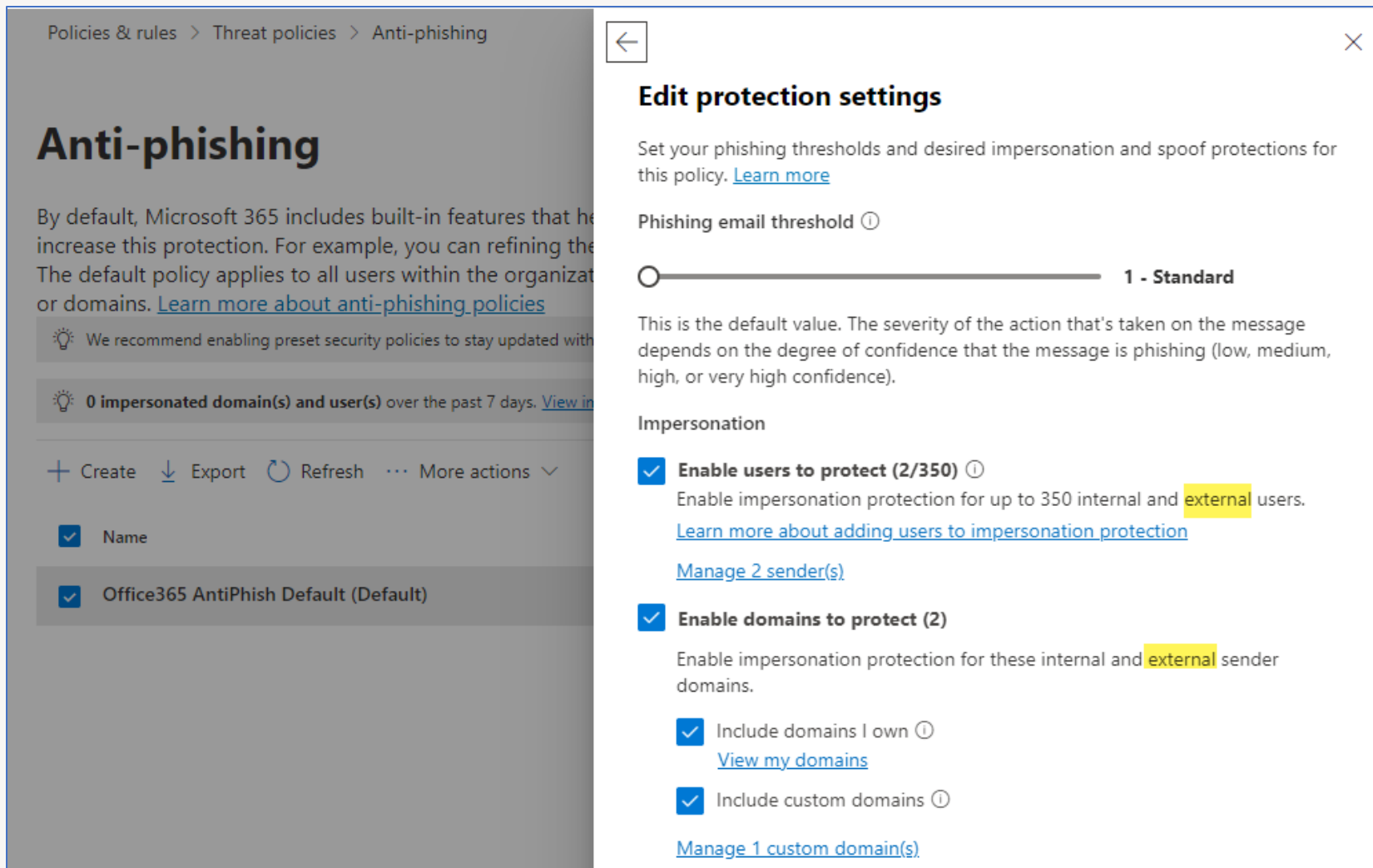
Malware

AdminOnlyAccessPolicy

High-confidence phishing

AdminOnlyAccessPolicy

Defender for Office 365 – Anti-Phishing Policy



The screenshot shows the 'Anti-phishing' policy settings in the Microsoft Defender for Office 365 console. The left sidebar displays the 'Policies & rules > Threat policies > Anti-phishing' breadcrumb, the 'Anti-phishing' title, and a list of policies with 'Office365 AntiPhish Default (Default)' selected. The main content area is titled 'Edit protection settings' and includes a back arrow and a close button. It contains instructions on setting phishing thresholds and impersonation/spoof protections, a 'Phishing email threshold' slider set to '1 - Standard', and two checked options for impersonation protection: 'Enable users to protect (2/350)' and 'Enable domains to protect (2)'. Both options include links to manage users and domains.

Policies & rules > Threat policies > Anti-phishing

Anti-phishing

By default, Microsoft 365 includes built-in features that help you increase this protection. For example, you can refine the policy. The default policy applies to all users within the organization or domains. [Learn more about anti-phishing policies](#)

💡 We recommend enabling preset security policies to stay updated with the latest threats.

💡 0 impersonated domain(s) and user(s) over the past 7 days. [View in details](#)

+ Create ↓ Export ↻ Refresh ⋮ More actions

✓	Name
✓	Office365 AntiPhish Default (Default)

Edit protection settings

Set your phishing thresholds and desired impersonation and spoof protections for this policy. [Learn more](#)

Phishing email threshold ⓘ

○ ————— 1 - Standard

This is the default value. The severity of the action that's taken on the message depends on the degree of confidence that the message is phishing (low, medium, high, or very high confidence).

Impersonation

✓ **Enable users to protect (2/350)** ⓘ
Enable impersonation protection for up to 350 internal and external users.
[Learn more about adding users to impersonation protection](#)
[Manage 2 sender\(s\)](#)

✓ **Enable domains to protect (2)**
Enable impersonation protection for these internal and external sender domains.

✓ Include domains I own ⓘ
[View my domains](#)

✓ Include custom domains ⓘ
[Manage 1 custom domain\(s\)](#)

Defender for Office 365 – Anti-Phishing Policy

Anti-phishing

By default, Microsoft 365 includes built-in features that help protect your users from phishing attacks. Set up anti-phishing protection. For example, you can refining the settings to better detect and prevent impersonation and spoofing attacks. To protect users within the organization. You can create custom, higher priority policies for specific users, groups or domains. [Learn more about anti-phishing policies](#)



We recommend enabling preset security policies to stay updated with new security controls and our recommended settings. [View preset security policies](#)



0 impersonated domain(s) and user(s) over the past 7 days. [View impersonations](#)



Create



Export



Refresh

3 items

 Search



Name

Status

Priority



Strict Anti-Phishing Policy

● On

0



Standard Anti-Phishing Policy

● On

1

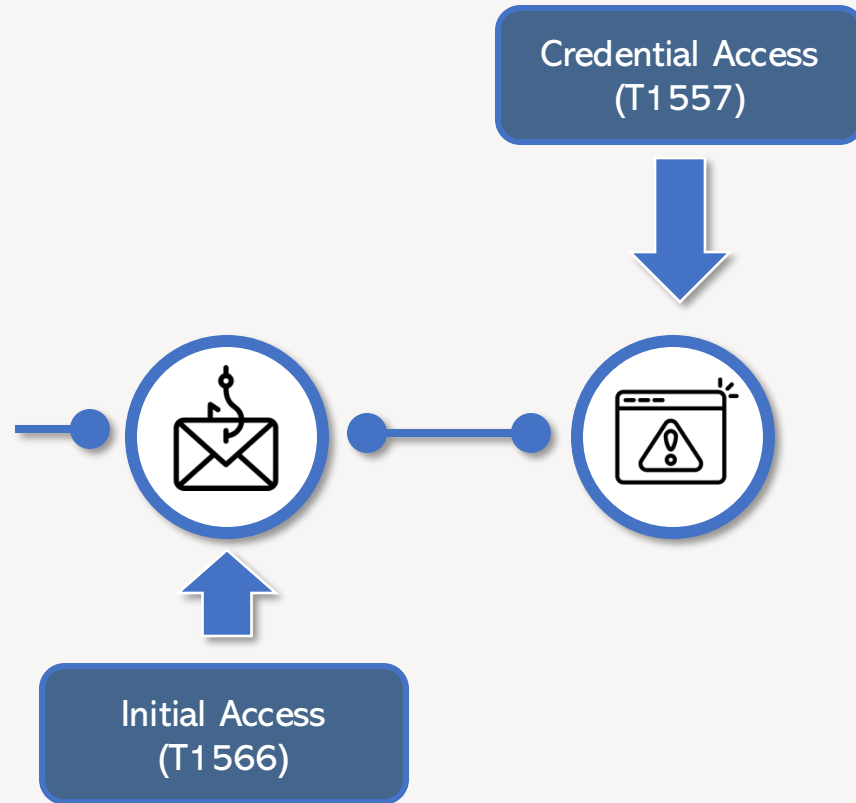


Office365 AntiPhish Default (Default)

● Always on

Lowest

Credential Access / AiTM (T1557)





Minimise risk

First line of defence

- » Phishing-resistant credentials to defeat proxy-based AiTM risk
- » Device management and endpoint monitoring (Intune + MDE)
- » Device based Conditional Access – Require compliant devices
- » Restrict use of Device Code Flow



Detect + Mitigate

Automated response to risk signals

- » Identity Protection – token replay detection (Enriched with MDE)
 - » Elevates user & session risk
 - » Revoke session with Continuous Access Evaluation in near real time
- » Risk based Conditional Access
 - » Require fresh phishing-resistant MFA on elevated sign-in risk
 - » Remediate users with high user risk

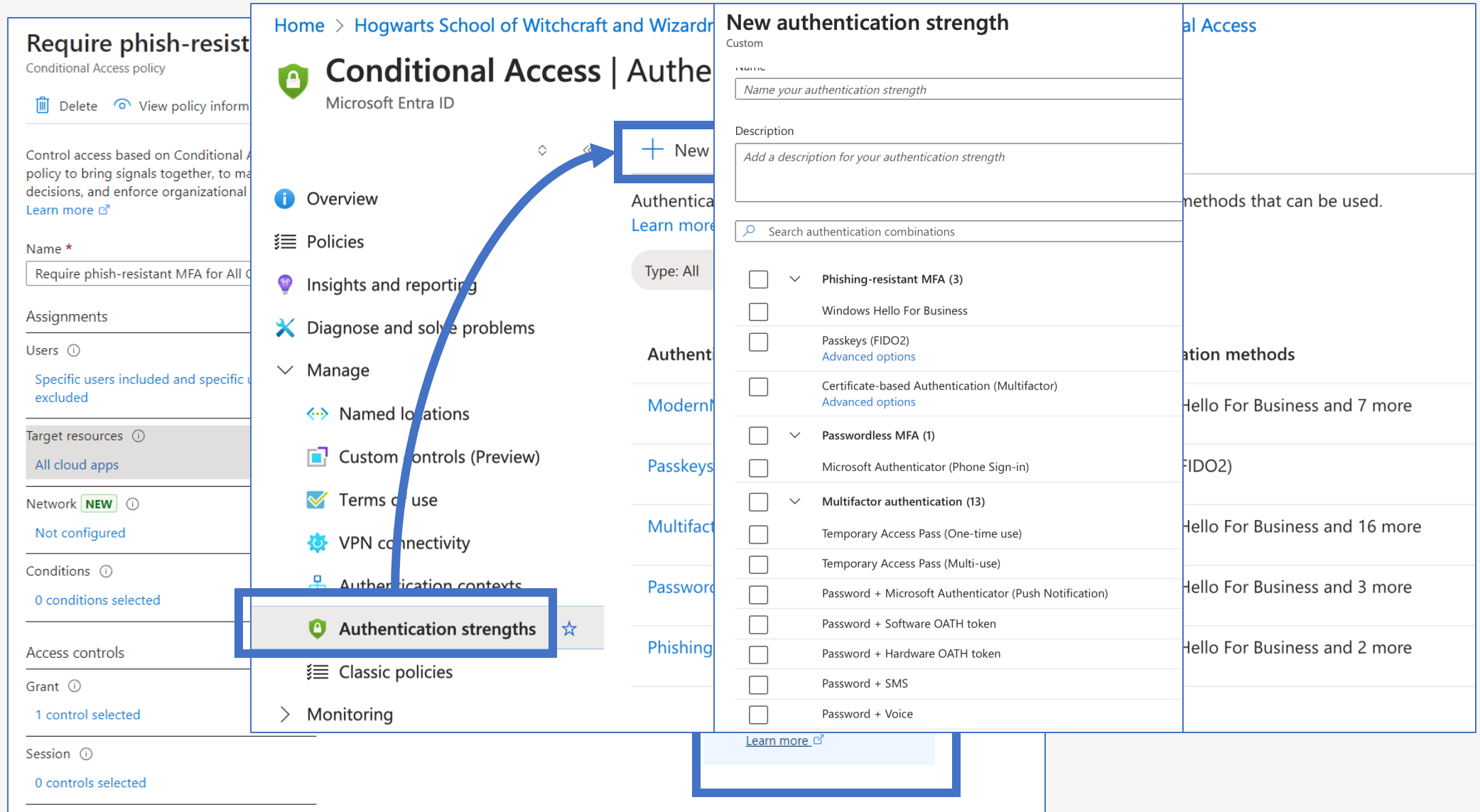


Protect against replay

Enforce use of high trust access with Conditional Access

- » Token Protection: Use of bound tokens reduces risk of replay
- » Entra Global Secure Access – compliant network check
- » IP Allowlisting: Deny access for non-trusted IP range

Conditional Access - Authentication Strengths



The screenshot displays the Microsoft Entra ID Conditional Access console. The left sidebar shows the 'Authentication strengths' section highlighted. The main content area shows the 'New authentication strength' form, which is currently empty. A blue arrow points from the 'Authentication strengths' link in the sidebar to the '+ New' button in the main content area. The right sidebar shows a list of authentication methods that can be used, including Phishing-resistant MFA, Windows Hello For Business, Passkeys (FIDO2), Certificate-based Authentication (Multifactor), Passwordless MFA, Multifactor authentication, and Password + Microsoft Authenticator (Push Notification).

Require phish-resistant
Conditional Access policy

Delete View policy information

Control access based on Conditional Access policy to bring signals together, to make decisions, and enforce organizational policies. [Learn more](#)

Name *

Require phish-resistant MFA for All Cloud Apps

Assignments

Users ①

[Specific users included and specific users excluded](#)

Target resources ①

All cloud apps

Network **NEW** ①

Not configured

Conditions ①

0 conditions selected

Access controls

Grant ①

1 control selected

Session ①

0 controls selected

Home > Hogwarts School of Witchcraft and Wizardry

Conditional Access | Authentication Strengths
Microsoft Entra ID

Overview
Policies
Insights and reporting
Diagnose and solve problems
Manage
Named locations
Custom controls (Preview)
Terms of use
VPN connectivity
Authentication contexts
Authentication strengths
Classic policies
Monitoring

+ New

Authentication strength

Name your authentication strength

Description

Add a description for your authentication strength

Search authentication combinations

Type: All

Phishing-resistant MFA (3)
Windows Hello For Business
Passkeys (FIDO2) [Advanced options](#)
Certificate-based Authentication (Multifactor) [Advanced options](#)
Passwordless MFA (1)
Microsoft Authenticator (Phone Sign-in)
Multifactor authentication (13)
Temporary Access Pass (One-time use)
Temporary Access Pass (Multi-use)
Password + Microsoft Authenticator (Push Notification)
Password + Software OATH token
Password + Hardware OATH token
Password + SMS
Password + Voice

[Learn more](#)

Authentication methods that can be used.

Authentication methods

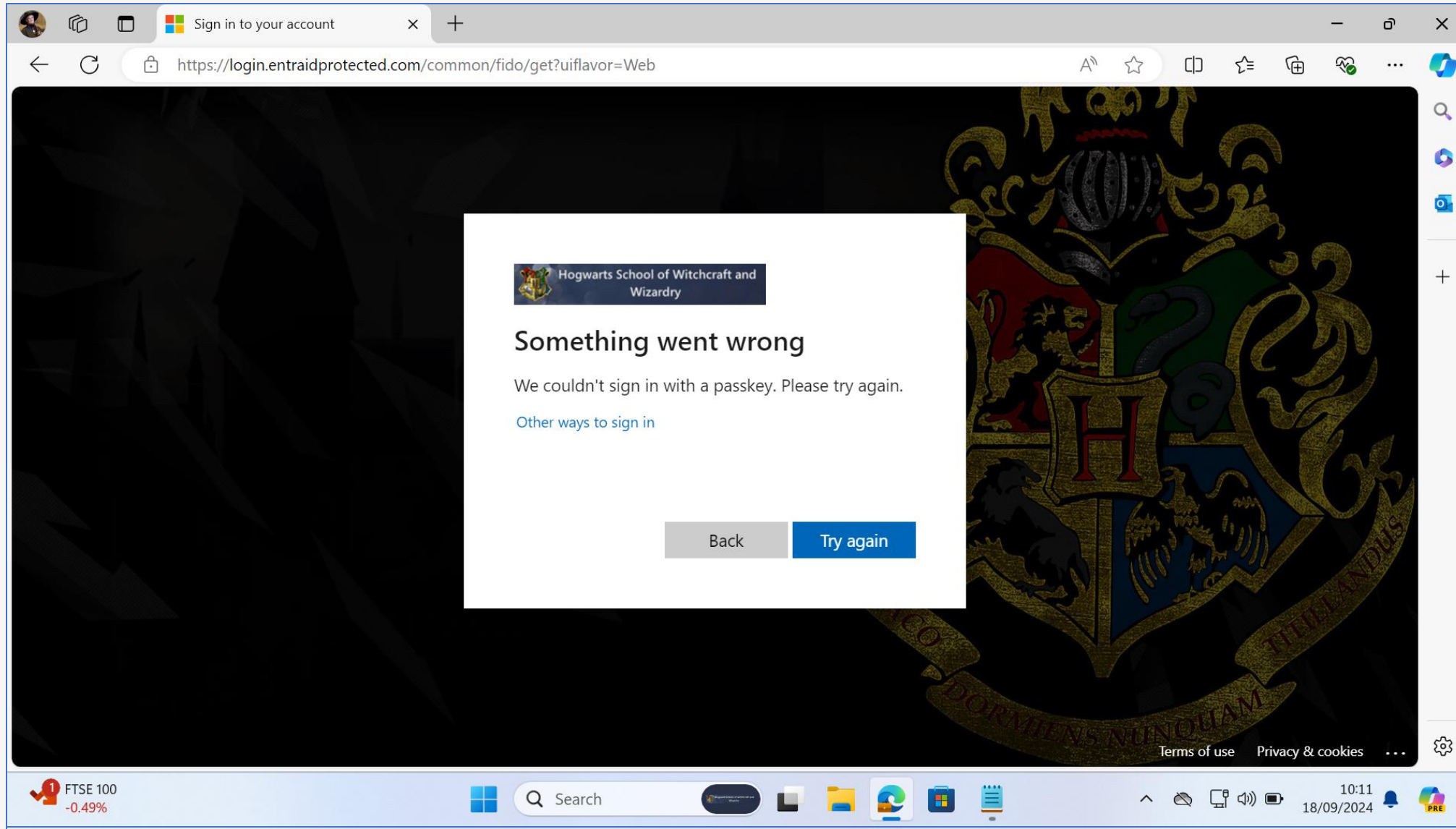
Windows Hello For Business and 7 more

Passkeys (FIDO2)

Windows Hello For Business and 16 more

Windows Hello For Business and 3 more

Windows Hello For Business and 2 more



Authentication Strengths – Enforce Phish-Resistant MFA

```
[09:09:44] [imp] [1] [ms365] new visitor has arrived: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/128.0.0.0 Safari/537.36 Edg/128.0.0.0 (86.20.79.186)
[09:09:44] [inf] [1] [ms365] landing URL: https://login.entraidprotected.com/hGHCvHnQ
[09:10:12] [+++] [1] Username: [2H4o1hNgdK2Osg4iPbqp5XMH40eu1nPWsdboFhv+bCE=7:1:CANARY:uh3t8d+wQtNvu0ossd76Gz7qx/08PhiO+BK9LMMJS0o=]
```

Device Compliance

Home > Security | Conditional Access > Conditional Access | Policies >

Require MDM-enrolled and compliant device to access

Conditional Access policy

Delete View policy information

Assignments

Users ①

[Specific users included and specific users excluded](#)

Target resources ①

[All cloud apps](#)

Network **NEW** ①

[Not configured](#)

Conditions ①

1 condition selected

Access controls

Grant ①

[Block access](#)

Session ①

0 controls selected

Enable policy

Sign-in risk ①

Sign-in risk level is the likelihood that the sign-in session is compromised.

[Not configured](#)

Insider risk ①

Insider risk assesses the user's risky data-related activity in Microsoft Purview Insider Risk Management.

[Not configured](#)

Device platforms ①

[Not configured](#)

Locations ①

[Not configured](#)

Client apps ①

[Not configured](#)

Filter for devices ①

[Exclude filtered devices](#)

Filter for devices

Configure a filter to apply policy to specific devices. [Learn more](#)

Configure ①

Yes No

Devices matching the rule:

☐ Include filtered devices in policy

☒ Exclude filtered devices from policy

You can use the rule builder or rule syntax text box to create or edit the filter rule.

And/Or	Property	Operator	Value	
	isCompliant	Equals	True	
Or	trustType	Equals	Microsoft Entra hybrid joined	

[+ Add expression](#)

Rule syntax ① [Edit](#)

```
device.isCompliant -eq True -or device.trustType -eq "ServerAD"
```

Grant

Control access enforcement to block or grant access. [Learn more](#)

☒ **Block access**

☐ Grant access

- <<
- Home
- Dashboard
- All services
- Devices
- Apps
- Endpoint security
- Reports
- Users
- Groups
- Tenant administration
- Troubleshooting support

Windows 10/11 compliance policy ...

Windows 10 and later

- ✓ Basics
- 2 Compliance settings**
- 3 Actions for noncompliance
- 4 Assignments
- 5 Review + create

- Custom Compliance
- Device Health
- Device Properties

Configuration Manager Compliance

System Security

Microsoft Defender for Endpoint

Microsoft Defender for Endpoint rules

Require the device to be at or under the machine risk score: ⓘ ⓘ

Not configured

Clear

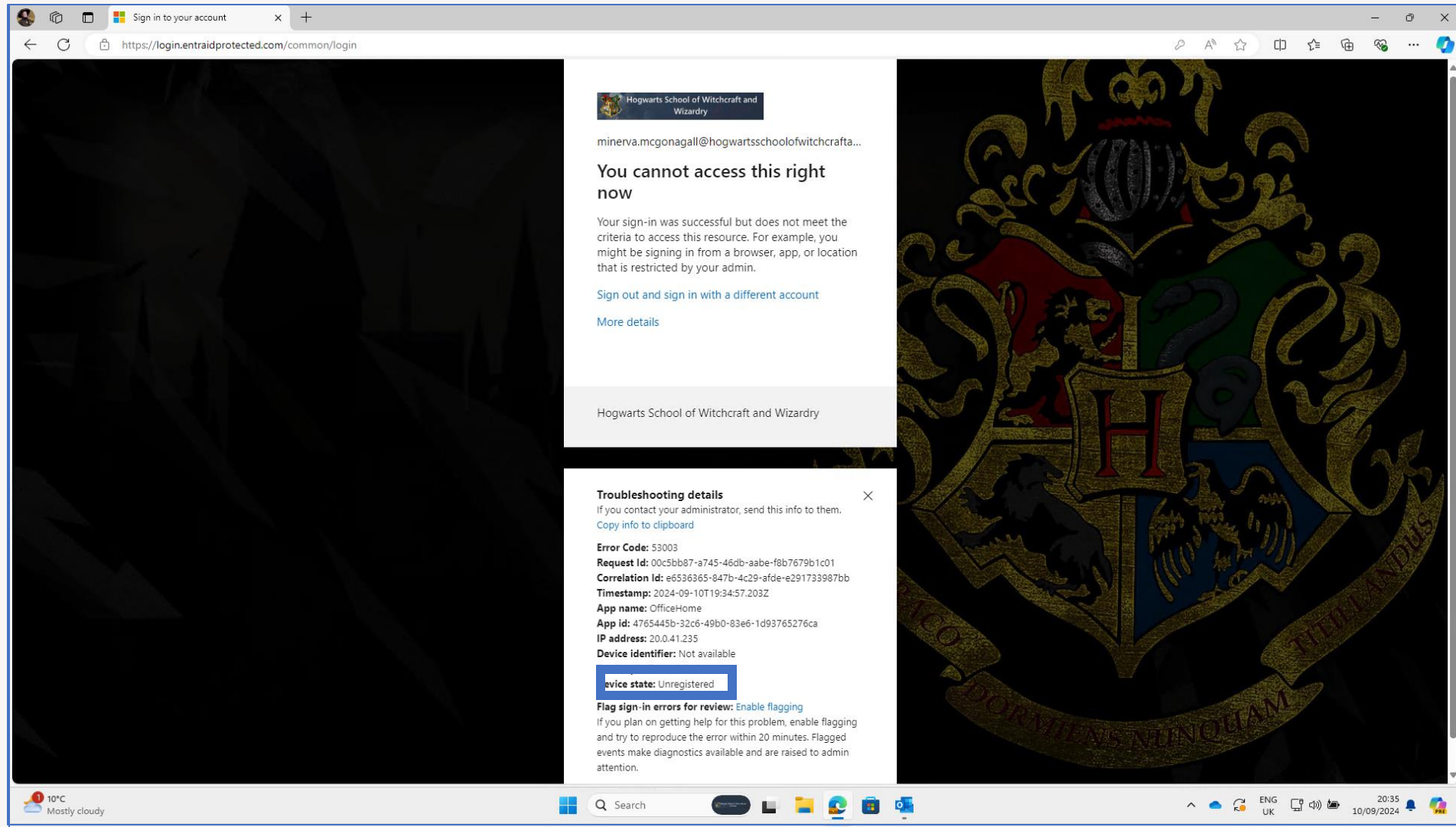
Low

Medium

High

Clear

Device Compliance



Sign in to your account

https://login.entraidprotected.com/common/login

Hogwarts School of Witchcraft and Wizardry

minerva.mcgonagall@hogwartsschoolofwitchcrafta...

You cannot access this right now

Your sign-in was successful but does not meet the criteria to access this resource. For example, you might be signing in from a browser, app, or location that is restricted by your admin.

[Sign out and sign in with a different account](#)

[More details](#)

Hogwarts School of Witchcraft and Wizardry

Troubleshooting details ✕

If you contact your administrator, send this info to them.
[Copy info to clipboard](#)

Error Code: 53003
Request Id: 00c5bb87-a745-46db-aabe-f8b7679b1c01
Correlation Id: e6536365-847b-4c29-afde-e291733987bb
Timestamp: 2024-09-10T19:34:57.203Z
App name: OfficeHome
App id: 4765445b-32c6-49b0-83e6-1d93765276ca
IP address: 20.0.41.235
Device identifier: Not available
Device state: Unregistered

Flag sign-in errors for review: [Enable flagging](#)

If you plan on getting help for this problem, enable flagging and try to reproduce the error within 20 minutes. Flagged events make diagnostics available and are raised to admin attention.

10°C Mostly cloudy

Search

ENG UK

20:35 10/09/2024

Device Compliance

```
steve@DeathEaters-Evilginx: . X + v
[19:33:12] [inf] Evilginx Mastery Course: https://academy.breakdev.org/evilginx-mastery (learn how to create phishlets)
[19:33:12] [inf] loading phishlets from: /home/steve/evilginx/phishlets
[19:33:12] [inf] loading configuration from: /home/steve/.evilginx
[19:33:12] [inf] blacklist: loaded 0 ip addresses and 0 ip masks
[19:33:12] [inf] obtaining and setting up 3 TLS certificates - please wait up to 60 seconds...
[19:33:12] [inf] successfully set up all TLS certificates

+-----+-----+-----+-----+-----+
| phishlet | status | visibility | hostname | unauth_url |
+-----+-----+-----+-----+-----+
| ms365    | enabled | visible   | entraidprotec... |
+-----+-----+-----+-----+-----+

[19:33:19] [imp] [0] [ms365] new visitor has arrived: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML
L, like Gecko) Chrome/128.0.0.0 Safari/537.36 Edg/128.0.0.0 (86.20.79.186)
[19:33:19] [inf] [0] [ms365] landing URL: https://login.entraidprotected.com/hGHCvhNQ
[19:34:44] [+++] [0] Password: [Triwizard-Tourney123!]
[19:34:44] [+++] [0] Username: [minerva.mcgonagall@hogwartsschoolofwitchcraftandwizardry.co.uk]
[19:34:44] [+++] [0] Username: [minerva.mcgonagall@hogwartsschoolofwitchcraftandwizardry.co.uk]
:
```

Defender for Endpoint

Alerts > Stolen logon session cookie was used

Part of incident: Stolen logon session cookie was used involving one user [View incident page](#)

hogwartsschoolofwitchcraftandwizar...

What happened

The session cookie was detected to be compromised. Microsoft 365 Defender alerts on the earliest observed event in this session.

Recommended actions

A. Validate the alert.

1. Search for the relevant login event in the AA...

[Read more](#)

Related events

9/17/2024 9:05:49 PM	 Minerva McGonagall logged on to Microsoft 365						
	<table><tr><td>Action type</td><td>LogonSuccess</td></tr><tr><td>Logon type</td><td>SAS:ProcessAuth</td></tr><tr><td>Account display name</td><td>Minerva McGonagall</td></tr></table>	Action type	LogonSuccess	Logon type	SAS:ProcessAuth	Account display name	Minerva McGonagall
Action type	LogonSuccess						
Logon type	SAS:ProcessAuth						
Account display name	Minerva McGonagall						

Stolen logon session cookie was used

Medium | Unknown | New

[Manage alert](#) [Link alert to another incident](#) ...

INSIGHT

Quickly classify this alert

Classify alerts to improve alert accuracy and get more insights about threats to your organization.

[Classify alert](#)

Alert state

Classification	Assigned to
Not Set	Unassigned
Set Classification	

Alert details

Category	MITRE ATT&CK Techniques
Credential access	T1539: Steal Web Session Coo...

 Oct 22, 2023 7:11 PM • New

Possible attempt to access Primary Refresh Token (PRT)

 msedgewin10  IEUser

[Pin](#) [Unpin](#)

Entra ID Protection

Home > Identity Protection

Identity Protection | Risky users

Search

Learn more Download Unselect all

Dashboard Tutorials Diagnose and solve problems Protect Report Settings

Want to allow automatic risk remediation? Setup

Auto refresh : Off Show dates as : Last 30 days

☒ User

↑↓

☒ Minerva McGonagall

Risky User Details

Reset password Confirm user compromised Confirm user safe Dismiss user risk Block user

Basic info Recent risky sign-ins Detections not linked to a sign-in Risk history

Detection type	Time Detected	Detection risk state	Detection risk level	Detection risk de...
Attacker in the Middle	9/18/2024, 12:03:24 PM	At risk	High	-

Home > Identity Protection

Identity Protection | Risky users

Search

Learn more Download Unselect all

Dashboard Tutorials Diagnose and solve problems Protect Report Settings Troubleshooting + Support

Want to allow automatic risk remediation? Setup

Auto refresh : Off Show dates as : Last 30 days

☒ User

↑↓

☒ Minerva McGonagall

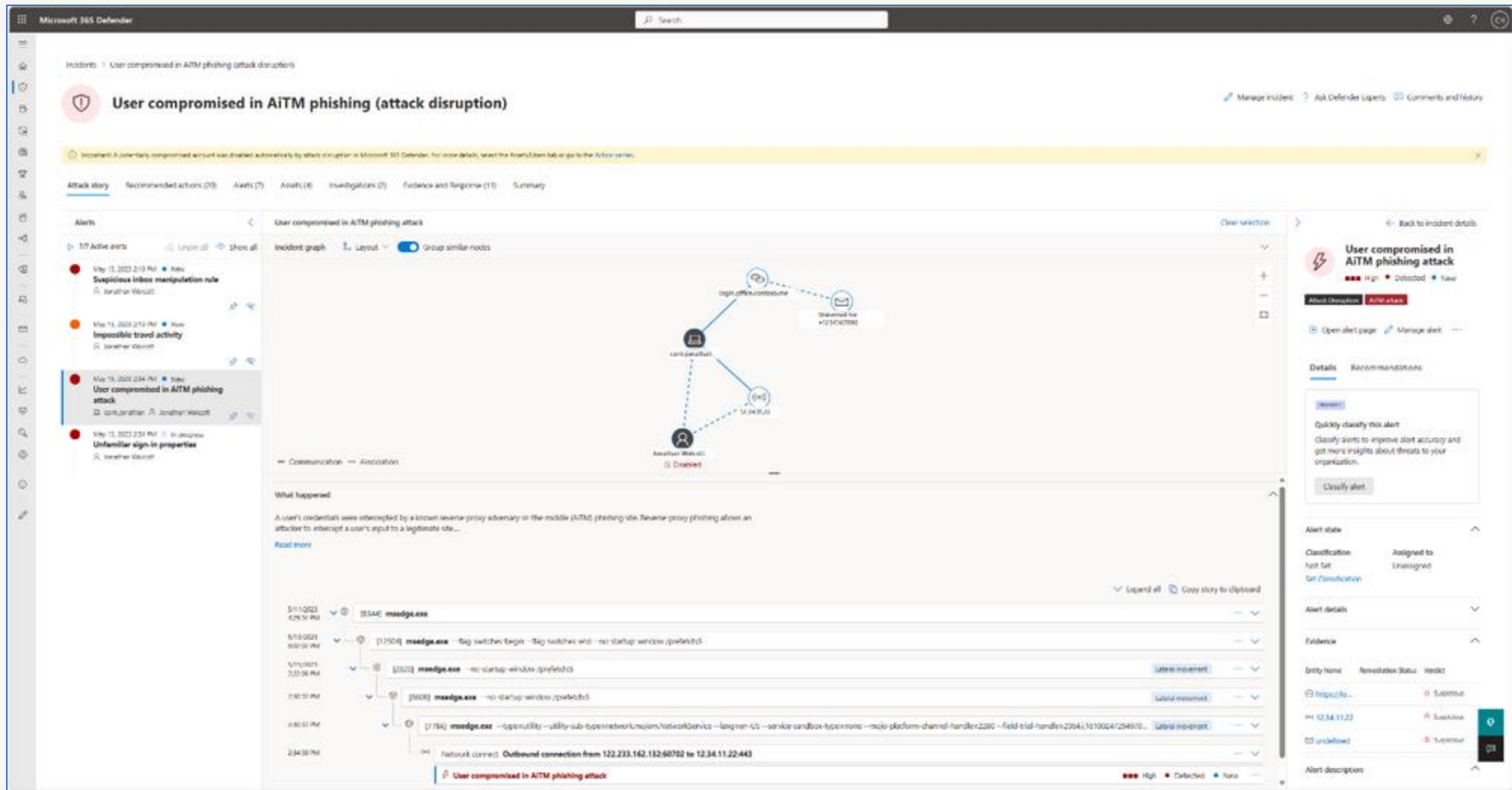
Risky User Details

Reset password Confirm user compromised Confirm user safe Dismiss user risk Block user

Basic info Recent risky sign-ins Detections not linked to a sign-in Risk history

Date	Activity	Actor	Risk state	Risk level
9/18/2024, 12:27:49 PM	Attacker in the Middle	Microsoft Entra ID	At risk	High
9/17/2024, 9:50:17 PM	User performed secured ...	Nate Admin	Remediated	-
8/29/2024, 9:14:23 PM	Additional risk detected	Microsoft Entra ID	Dismissed	-

Defender XDR – Automatic Attack Disruption

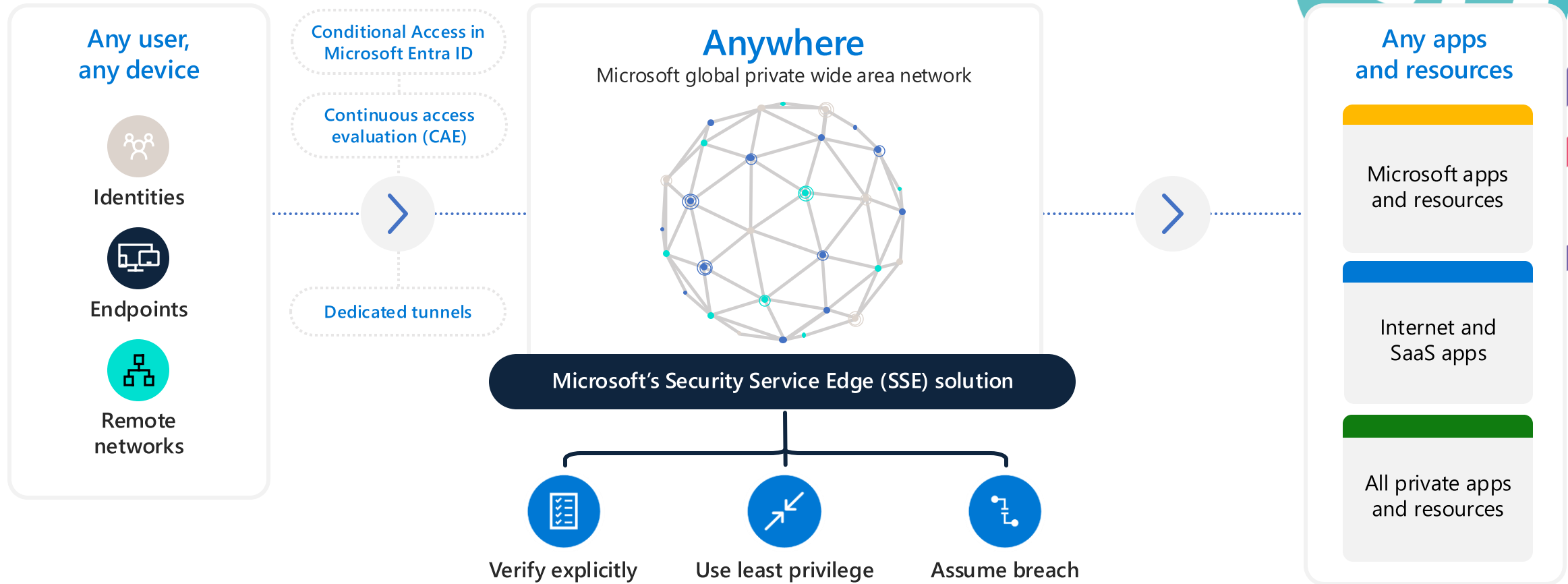


The screenshot displays the Microsoft 365 Defender interface. The main incident view is titled "User compromised in AiTM phishing (attack disruption)". A yellow banner at the top states: "Important: A potentially compromised account was disabled automatically by attack disruption in Microsoft 365 Defender. For more details, visit the [Incident User tab](#) or go to the [Action center](#)."

The interface is divided into several sections:

- Alerts:** A list of alerts on the left, including "Suspicious inbox manipulation rule", "Impossible travel activity", and the selected "User compromised in AiTM phishing attack".
- Incident Graph:** A central graph showing the attack flow. Nodes include "login.office.com/home", "compromised", "Outbound connection", and "User compromised in AiTM phishing attack".
- What happened:** A text description stating: "A user's credentials were intercepted by a known reverse proxy adversary in the middle (AiTM) phishing site. Reverse proxy phishing allows an attacker to intercept a user's input to a legitimate site..."
- Timeline:** A detailed log of events at the bottom, showing process execution (msedge.exe) and network connections. The final event is "Outbound connection from 122.233.162.132:60702 to 12.34.11.22:443".
- Alert details:** A sidebar on the right showing the alert classification (High), detection status (Detected), and a "Classify alert" button.

Microsoft's identity-centric SSE solution



Manage traffic forwarding profiles

Traffic forwarding profiles enable admins to forward specific traffic to Global Secure Access. Assign traffic forwarding profiles to users running the Global Secure Access client. For clientless devices, use the Microsoft profile to assign to remote networks.

[Learn more](#)

 One or more profiles are configured and ready to use. To finish setup, Download [Global Secure Access client](#).



Microsoft traffic profile

Enabled

Last modified on 08/12/2025, 10:34 AM



Applies to

Internet traffic to Microsoft services



Microsoft traffic policies

4 policies [View](#)



Linked Conditional Access policies

59 policies [View](#)



User and group assignments

All users assigned [View](#)



Remote network assignments

0 assigned remote networks [View](#)



Private access profile

Enabled

Last modified on 10/13/2025, 10:36 AM



Applies to

Private resources



Private access policies

Quick Access, 0 Applications



Linked Conditional Access policies

None



User and group assignments

0 users, 1 groups assigned [View](#)



Remote network assignments

Not applicable



Internet access profile

Enabled

Last modified on not available



Applies to

All internet traffic, except for the Microsoft traffic profile



Internet access policies

4 policies [View](#)



Linked Conditional Access policies

59 policies [View](#)



User and group assignments

0 users, 2 groups assigned [View](#)



Remote network assignments

Not applicable



218-Internals-GSA-M365-Office365-Desktop-NonCompliantNetwork-Block

Conditional Access policy

Delete View policy information View policy impact

Control access based on Conditional Access policy to bring signals together, to make decisions, and enforce organizational policies. [Learn more](#)

Name *
218-Internals-GSA-M365-Office365-Deskto...

Assignments

Users ⓘ
Specific users included and specific users excluded

Target resources ⓘ
1 resource included and 2 resources excluded

Network **NEW** ⓘ
Any network or location and 1 excluded

Conditions ⓘ
2 conditions selected

Access controls
Grant ⓘ
Block access

Session ⓘ
0 controls selected

Control access based on all or specific apps, internet resources, actions, or authentication context. [Learn more](#)

Select what this policy applies to
Resources (formerly cloud apps)

Include Exclude

- ☐ None
- ☐ All internet resources with Global Secure Access
- ☐ All resources (formerly 'All cloud apps')
- ☒ Select resources

Edit filter
None

Select
Office 365
Office 365 ⓘ

i To create a Conditional Access policy targeting members in your tenant with Global Secure Access (GSA) as a resource, make sure GSA is deployed in your tenant. [Learn more](#)

Control user access based on their network or physical location. [Learn more](#)

Configure ⓘ
Yes No

Include Exclude

- ☒ Any network or location
- ☐ All trusted networks and locations
- ☐ All Compliant Network locations
- ☐ Selected networks and locations

! All Compliant Network locations" does not work with "Require app protection policy" or "Require approved client app" grant controls. [Learn more](#)

i To create a Conditional Access policy ensuring your tenant's members are coming from their compliant network, make sure Global Secure Access (GSA) is deployed and Adaptive Access Signaling in GSA is enabled in your tenant. Learn more on how to [enable GSA Adaptive Access Signaling](#).

i 'Locations' condition is moving! Locations will become the 'Network' assignment with a new Global Secure Access capability of 'All Compliant network locations'. No action required. [Learn more](#)

Control user access based on their network or physical location. [Learn more](#)

Configure ⓘ
Yes No

Include Exclude

- Select the locations to exempt from the policy
- ☐ All trusted networks and locations
 - ☒ All Compliant Network locations
 - ☐ Selected networks and locations

! All Compliant Network locations" does not work with "Require app protection policy" or "Require approved client app" grant controls. [Learn more](#)

i To create a Conditional Access policy ensuring your tenant's members are coming from their compliant network, make sure Global Secure Access (GSA) is deployed and Adaptive Access Signaling in GSA is enabled in your tenant. Learn more on how to [enable GSA Adaptive Access Signaling](#).

i 'Locations' condition is moving! Locations will become the 'Network' assignment with a new Global Secure Access capability of 'All Compliant network locations'. No action required. [Learn more](#)

Device platforms

Apply policy to selected device platforms. [Learn more](#)

Configure ⓘ
Yes No

Include Exclude

- ☒ Any device
- ☐ Select device platforms
 - ☐ Android
 - ☐ iOS
 - ☐ Windows Phone
 - ☐ Windows
 - ☐ macOS
 - ☐ Linux

Device platforms

Apply policy to selected device platforms. [Learn more](#)

Configure ⓘ
Yes No

Include Exclude

- ☒ Android
- ☒ iOS
- ☐ Windows Phone
- ☐ Windows
- ☐ macOS
- ☐ Linux

Grant

Control access enforcement to block or grant access. [Learn more](#)

☒ Block access

☐ Grant access

- ☐ Require multifactor authentication ⓘ
- ☐ Require authentication strength ⓘ
- ☐ Require device to be marked as compliant ⓘ
- ☐ Require Microsoft Entra hybrid joined device ⓘ
- ☐ Require approved client app ⓘ
[See list of approved client apps](#)
- ☐ Require app protection policy ⓘ
[See list of policy protected client apps](#)
- ☐ Require password change ⓘ
- ☐ Test TOUs

For multiple controls

- ☒ Require all the selected controls
- ☐ Require one of the selected controls

Sign in to your account

https://login.microsoftonline.com/common/reprocess?ctx=rQQIARAAjZJBTNNgFMfbFeYYCgOjMZ7UJla69pu3...



internal@

You cannot access this right now

Your sign-in was successful but does not meet the criteria to access this resource. For example, you might be signing in from a browser, app, or location that is restricted by your admin.

[Sign out and sign in with a different account](#)

[More details](#)

Welcome to Nate Hutchinson

Please sign in using your corporate credentials.

Multifactor Authentication (MFA)

For increased security, MFA is now a requirement for all staff. You can find more information including a setup guide and video at www.domain.com/MFA

Contact Support





16:32 15/10/2025

Token Protection in Azure AD Conditional Access

– A Savior to Control Token Phishing!



229-Internals-EXO+SPO+Teams-DesktopClient-Windows-TokenProtection ...

Conditional Access policy

 Delete  View policy information  View policy impact

Control access based on Conditional Access policy to bring signals together, to make decisions, and enforce organizational policies. [Learn more](#)

Name *

229-Internals-EXO+SPO+Teams-DesktopCli...

Assignments

Users 

[Specific users included and specific users excluded](#)

Target resources 

3 resources included

Network **NEW** 

[Not configured](#)

Conditions 

[2 conditions selected](#)

Access controls

Grant 

[0 controls selected](#)

Session 

[Require token protection for sign-in sessions \(Generally available for Windows. Preview for MacOS, iOS\)](#)

Control access based on all or specific apps, internet resources, actions, or authentication context. [Learn more](#)

Select what this policy applies to

Resources (formerly cloud apps) 

Include Exclude

- ☐ None
- ☐ All internet resources with Global Secure Access
- ☐ All resources (formerly 'All cloud apps')
- ☒ Select resources

Edit filter

[None](#)

Select

[Office 365 SharePoint Online and 2 more](#)

- | | | |
|----|--|-----|
| MT | Microsoft Teams Services
cc15fd57-2c6c-4117-a88c-83b1d56b4bbe | ... |
| O3 | Office 365 Exchange Online
00000002-0000-0ff1-ce00-000000000000 | ... |
| O3 | Office 365 SharePoint Online
00000003-0000-0ff1-ce00-000000000000 | ... |

 Selecting SharePoint Online will also affect apps such as Microsoft Teams, Planner, Delve, MyAnalytics, and Newsfeed. [Learn more](#)

 Selecting Office 365 Exchange Online will also affect apps such as OneDrive and Teams. [Learn more](#)

 To create a Conditional Access policy targeting members in your tenant with Global Secure Access (GSA) as a resource, make sure GSA is deployed in your tenant. [Learn more](#)

Device platforms

Apply policy to selected device platforms. [Learn more](#)

Configure 

Yes No

Include Exclude

- ☐ Any device
- ☒ Select device platforms
- ☐ Android
- ☐ iOS
- ☐ Windows Phone
- ☒ Windows
- ☐ macOS
- ☐ Linux

Client apps

Control user access to target specific client applications not using modern authentication. [Learn more](#)

Configure 

Yes No

Select the client apps this policy will apply to

Modern authentication clients

- ☐ Browser
- ☒ Mobile apps and desktop clients

Legacy authentication clients

- ☐ Exchange ActiveSync clients
- ☐ Other clients 

Session

Control access based on session controls to enable limited experiences within specific cloud applications. [Learn more](#)

☐ Use app enforced restrictions 

 This control only works with supported apps. Currently, Office 365, Exchange Online, and SharePoint Online are the only cloud apps that support app enforced restrictions. [Learn more](#)

☐ Use Conditional Access App Control 

☐ Sign-in frequency 

☐ Persistent browser session 

☐ Customize continuous access evaluation 

☐ Disable resilience defaults 

☒ Require token protection for sign-in sessions (Generally available for Windows. Preview for MacOS, iOS) 

 The control "Require token protection for sign-in sessions" only works with supported devices and applications. Unsupported devices and client applications will be blocked. [Learn more](#)

☐ Use Global Secure Access security profile 

 This option only works with Global Secure Access resources.

229-Internals-EXO+SPO+Teams-DesktopClient-Windows-TokenProtection ...

Conditional Access policy

Delete View policy information View policy impact

Control access based on Conditional Access policy to bring signals together, to make decisions, and enforce organization policies. [Learn more](#)

Name *

229-Internals-EXO+SPO+Teams-De

Assignments

Users ⓘ

Specific users included and specifically excluded

Target resources ⓘ

3 resources included

Network **NEW** ⓘ

Not configured

Conditions ⓘ

2 conditions selected

Access controls

Grant ⓘ

0 controls selected

Session ⓘ

Require token protection for sign-in sessions (Generally available for Windows. Preview for MacOS, iOS)

Warning

Your Conditional Access policy should only be configured for these applications. Selecting the **Office 365** application group might result in unintended failures. This change is an exception to the general rule that the **Office 365** application group should be selected in a Conditional Access policy.

Edit filter

None

Select

Office 365 SharePoint Online and 2 more

MT Microsoft Teams Services
cc15fd57-2c6c-4117-a88c-83b1d56b4bbe ...

O3 Office 365 Exchange Online
00000002-0000-0ff1-ce00-000000000000 ...

O3 Office 365 SharePoint Online
00000003-0000-0ff1-ce00-000000000000 ...

Warning Selecting SharePoint Online will also affect apps such as Microsoft Teams, Planner, Delve, MyAnalytics, and Newsfeed. [Learn more](#)

Warning Selecting Office 365 Exchange Online will also affect apps such as OneDrive and Teams. [Learn more](#)

Info To create a Conditional Access policy targeting members in your tenant with Global Secure Access (GSA) as a resource, make sure GSA is deployed in your tenant. [Learn more](#)

Select device platforms

☐ Android

☐ iOS

☐ Windows Phone

☒ Windows

☐ macOS

☐ Linux

☐ Browser

☒ Mobile apps and desktop clients

Legacy authentication clients

☐ Exchange ActiveSync clients

☐ Other clients ⓘ

enforced restrictions. [Learn more](#)

☐ Use Conditional Access App Control ⓘ

☐ Sign-in frequency ⓘ

☐ Persistent browser session ⓘ

☐ Customize continuous access evaluation ⓘ

☐ Disable resilience defaults ⓘ

☒ Require token protection for sign-in sessions (Generally available for Windows. Preview for MacOS, iOS) ⓘ

Info The control "Require token protection for sign-in sessions" only works with supported devices and applications. Unsupported devices and client applications will be blocked. [Learn more](#)

☐ Use Global Secure Access security profile ⓘ

Info This option only works with Global Secure Access resources.

229-Internals-EXO+SPO+Teams-DesktopClient-Windows-TokenProtection ...

Conditional Access policy

Delete View policy information View

Control access based on Conditional Access policy to bring signals together, to make decisions, and enforce organizational policies. [Learn more](#)

Name *

229-Internals-EXO+SPO+Teams-DesktopCli...

Assignments

Users ⓘ

Specific users included and specific users excluded

Target resources ⓘ

3 resources included

Network **NEW** ⓘ

Not configured

Conditions ⓘ

2 conditions selected

Access controls

Grant ⓘ

0 controls selected

Session ⓘ

Require token protection for sign-in sessions (Generally available for Windows. Preview for MacOS, iOS)

Tip

Since Conditional Access policies requiring token protection are currently only available for Windows devices, it's necessary to secure your environment against potential policy bypass when an attacker might appear to come from a different platform.

In addition, you should configure the following policies:

- [Block access from unknown platforms](#)
- [Require device compliance for all known platforms](#)

Select

Office 365 SharePoint Online and 2 more

- MT** Microsoft Teams Services
cc15fd57-2c6c-4117-a88c-83b1d56b4bbe ...
- O3** Office 365 Exchange Online
00000002-0000-0ff1-ce00-000000000000 ...
- O3** Office 365 SharePoint Online
00000003-0000-0ff1-ce00-000000000000 ...

⚠ Selecting SharePoint Online will also affect apps such as Microsoft Teams, Planner, Delve, MyAnalytics, and Newsfeed. [Learn more](#)

⚠ Selecting Office 365 Exchange Online will also affect apps such as OneDrive and Teams. [Learn more](#)

ℹ To create a Conditional Access policy targeting members in your tenant with Global Secure Access (GSA) as a resource, make sure GSA is deployed in your tenant. [Learn more](#)

- ☐ Windows Phone
- ☒ Windows
- ☐ macOS
- ☐ Linux

Legacy authentication clients

- ☐ Exchange ActiveSync clients
- ☐ Other clients ⓘ

☐ Sign-in frequency ⓘ

☐ Persistent browser session ⓘ

☐ Customize continuous access evaluation ⓘ

☐ Disable resilience defaults ⓘ

☒ Require token protection for sign-in sessions (Generally available for Windows. Preview for MacOS, iOS) ⓘ

ℹ The control "Require token protection for sign-in sessions" only works with supported devices and applications. Unsupported devices and client applications will be blocked. [Learn more](#)

☐ Use Global Secure Access security profile ⓘ

ℹ This option only works with Global Secure Access resources.

229-Internals-EXO+SPO+Teams-DesktopClient-Windows-TokenProtection

Conditional Access policy

Delete View policy information View policy impact

Control access based on Conditional Access policy to bring signals together, to make decisions, and enforce organizational policies. [Learn more](#)

Name *
229-Internals-EXO+SPO+Teams-DesktopCli...

Assignments

Users

Specific users included and specific users excluded

Target resources

3 resources included

Network NEW

Not configured

Conditions

2 conditions selected

Access controls

Grant

Control access based on all or specific apps, internet resources, actions, or authentication context. [Learn more](#)

Select what this policy applies to

Resources (formerly cloud apps)

Include Exclude

None

All internet resources with Global Secure Access

All resources (formerly 'All cloud apps')

Select resources

Edit filter

None

Select

Office 365 SharePoint Online and 2 more

MT Microsoft Teams Services
cc15fd57-2c6c-4117-a88c-83b1d56b4bbe

O3 Office 365 Exchange Online
00000002-0000-0ff1-ce00-000000000000

Device platforms

Apply policy to selected device platforms. [Learn more](#)

Configure

Yes

No

Include Exclude

Any device

Select device platforms

Android

iOS

Windows Phone

Windows

macOS

Linux

Client apps

Control user access to target specific client applications not using modern authentication. [Learn more](#)

Configure

Yes

No

Select the client apps this policy will apply to

Modern authentication clients

Browser

Mobile apps and desktop clients

Legacy authentication clients

Exchange ActiveSync clients

Other clients

Session

Control access based on session controls to enable limited experiences within specific cloud applications. [Learn more](#)

Use app enforced restrictions

This control only works with supported apps. Currently, Office 365, Exchange Online, and SharePoint Online are the only cloud apps that support app enforced restrictions. [Learn more](#)

Use Conditional Access App Control

Sign-in frequency

Persistent browser session

Customize continuous access evaluation

Disable resilience defaults

Require token protection for sign-in sessions (Generally available for macOS, iOS)

"Require token protection sessions" only works with devices and applications. If devices and client will be blocked.

Secure Access security

Warning

Not configuring the **Client Apps** condition, or leaving **Browser** selected might cause applications that use MSAL.js, such as Teams Web to be blocked.

To create a Conditional Access policy targeting members in your tenant with Global Secure Access (GSA) as a resource, make sure GSA is deployed in your tenant. [Learn more](#)

This option only works with Global Secure Access resources.

229-Internals-EXO+SPO+Teams-DesktopClient-Windows-TokenProtection

Conditional Access policy

Delete View policy information View policy impact

Control access based on Conditional Access policy to bring signals together, to make decisions, and enforce organizational policies. [Learn more](#)

Name *
229-Internals-EXO+SPO+Teams-DesktopCli...

Assignments

Users
[Specify users included and excluded](#)

Control access based on all or specific apps, internet resources, actions, or authentication context. [Learn more](#)

Select what this policy applies to
Resources (formerly cloud apps)

Include Exclude

- ☐ None
☐ All internet resources with Global Secure

Device platforms

Apply policy to selected device platforms. [Learn more](#)

Configure

Yes No

Client apps

Control user access to target specific client applications not using modern authentication. [Learn more](#)

Configure

Yes No

Session

Control access based on session controls to enable limited experiences within specific cloud applications. [Learn more](#)

☐ Use app enforced restrictions

Note

Use this policy as part of a broader strategy against token theft, as described in [Protecting tokens in Microsoft Entra](#).

Grant

0 controls selected

Session

Require token protection for sign-in sessions (Generally available for Windows. Preview for MacOS, iOS)

03 Office 365 Exchange Online
00000002-0000-0ff1-ce00-000000000000

03 Office 365 SharePoint Online
00000003-0000-0ff1-ce00-000000000000

☐ Linux

Selecting SharePoint Online will also affect apps such as Microsoft Teams, Planner, Delve, MyAnalytics, and Newsfeed. [Learn more](#)

Selecting Office 365 Exchange Online will also affect apps such as OneDrive and Teams. [Learn more](#)

To create a Conditional Access policy targeting members in your tenant with Global Secure Access (GSA) as a resource, make sure GSA is deployed in your tenant. [Learn more](#)

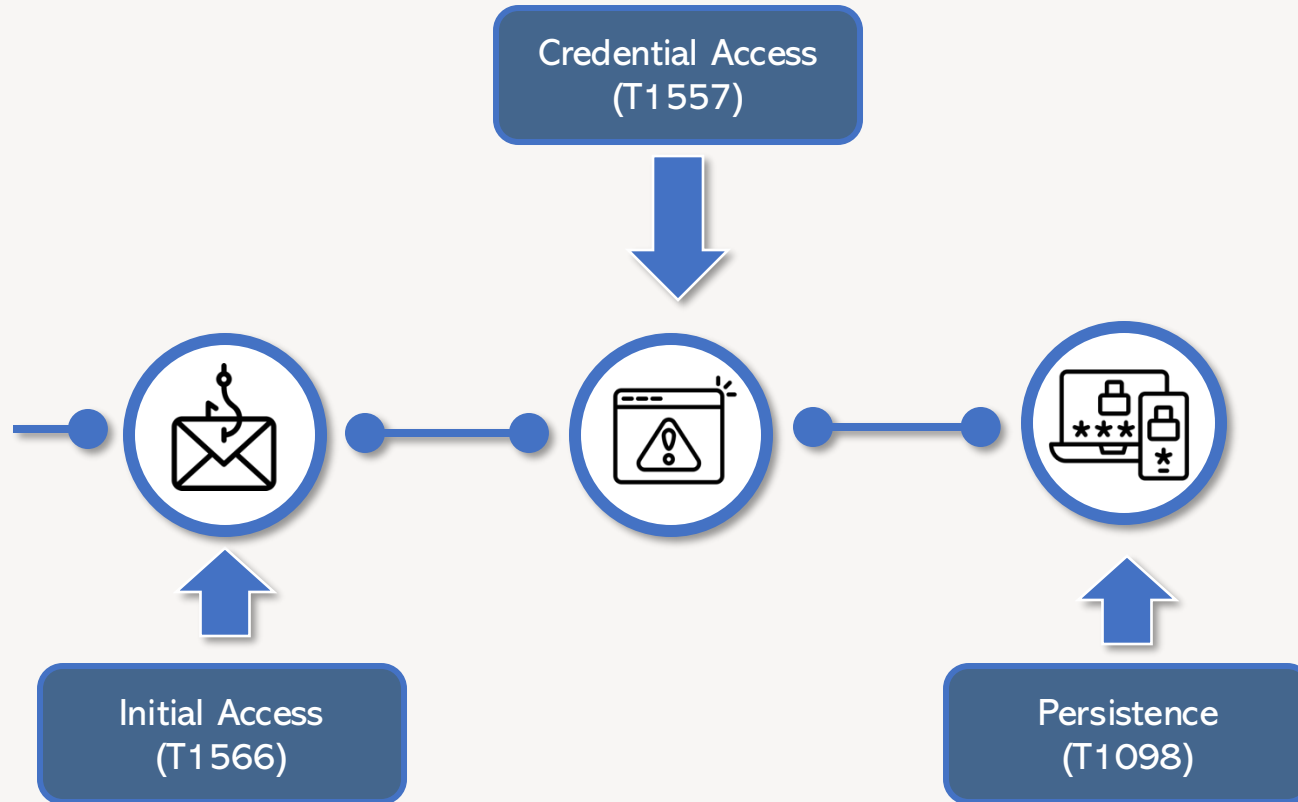
☒ Require token protection for sign-in sessions (Generally available for Windows. Preview for MacOS, iOS)

The control "Require token protection for sign-in sessions" only works with supported devices and applications. Unsupported devices and client applications will be blocked. [Learn more](#)

☐ Use Global Secure Access security profile

This option only works with Global Secure Access resources.

Persistence / Account Manipulation (T1098)



Secure Registration of Security Info

Home > Security | Conditional Access > Conditional Access | Policies >

Securing security info registration ...

Conditional Access policy

Delete

View policy information

1 user action included

Network **NEW**

Any network or location and all trusted locations excluded

Conditions

1 condition selected

Access controls

Grant

1 control selected

Session

0 controls selected

Insider risk

Insider risk assesses the user's risky data-related activity in Microsoft Purview Insider Risk Management.

Not configured

Device platforms

Not configured

Locations

Any network or location and all trusted locations excluded

Client apps

Not configured

Filter for devices

Not configured

Authentication flows (Preview)

Not configured

Filter for devices

Configure a filter to apply policy to specific devices. [Learn more](#)

Configure

Yes No

Devices matching the rule:

Include filtered devices in policy

Exclude filtered devices from policy

You can use the rule builder or rule syntax text box to create or edit the filter rule.

And/Or	Property	Operator	Value
	isCompliant	Equals	True
Or	TrustType	Equals	Microsoft Entra hybrid joined

+ Add expression

Rule syntax

device.isCompliant -eq True -or device.trustType -eq "ServerAD"

Grant

Control access enforcement to block or grant access. [Learn more](#)

Block access

Grant access

Secure Registration of Security Info

Home > Hogwarts School of Witchcraft and Wizardry | Security > Security | Conditional Access > Conditional Access | Policies >

Only register security info from Corporate Office ...

Conditional Access policy

 Delete  View policy information

Control access based on Conditional Access policy to bring signals together, to make decisions, and enforce organizational policies. [Learn more](#)

Name *

Only register security info from Corporate O...

Assignments

Users 

[Specific users included and specific users excluded](#)

Target resources 

[1 user action included](#)

Network **NEW** 

[Any network or location and 1 excluded](#)

Conditions 

[1 condition selected](#)

Enable policy

Report-only **On** Off

Control user access based on their network or physical location. [Learn more](#)

Configure 

Yes No

Include Exclude

Select the locations to exempt from the policy

☐ All trusted networks and locations

☐ All Compliant Network locations

☒ Selected networks and locations

Select

Corporate Office

Corporate Office ...

 To create a Conditional Access policy ensuring your tenant's members are

Grant

Control access enforcement to block or grant access. [Learn more](#)

☒ **Block access**

☐ Grant access

☐ Require multifactor authentication 

☐ Require authentication strength 

☐ Require device to be marked as compliant 

Defender for Identity

 **Suspicious additions to sensitive groups**

Medium | Unknown | New

 Manage alert |  Export | ...

INSIGHT

Quickly classify this alert

Classify alerts to improve alert accuracy and get more insights about threats to your organization.

Classify alert

Alert state

Classification

Not Set

Set Classification

Assigned to

Unassigned

Alert details

Category

Persistence

Detection source

Microsoft Defender for Identity

Service source

Microsoft Defender for Identity

Detection status

Unknown

Suspected Golden Ticket usage (encryption downgrade) (external ID 2000)

Previous name: Encryption

Severity: Medium

Description:

Encryption downgrade is fields that normally have brute force attempts. Vari Identity learns the Kerber that is unusual for the so

In a Golden Ticket alert, t computer was detected a anomaly (as in the other authentication request as

Learning period:

This alert has a learning p

MITRE:

Primary MITRE tactic

Secondary MITRE tactic

MITRE attack technique

MITRE attack sub-technique

Honeytoken user attributes modified (external ID 2427)

Severity: High

Description: Every user object in Active Directory has attributes that contain information such as first name, middle name, last name, phone number, address and more. Sometimes attackers will try and manipulate these objects for their benefit, for example by changing the phone number of an account to get access to any multifactor authentication attempt. Microsoft Defender for Identity will trigger this alert for any attribute modification against a pre-configured [honeytoken user](#).

Learning period:

None

MITRE:

Primary MITRE tactic

MITRE attack technique

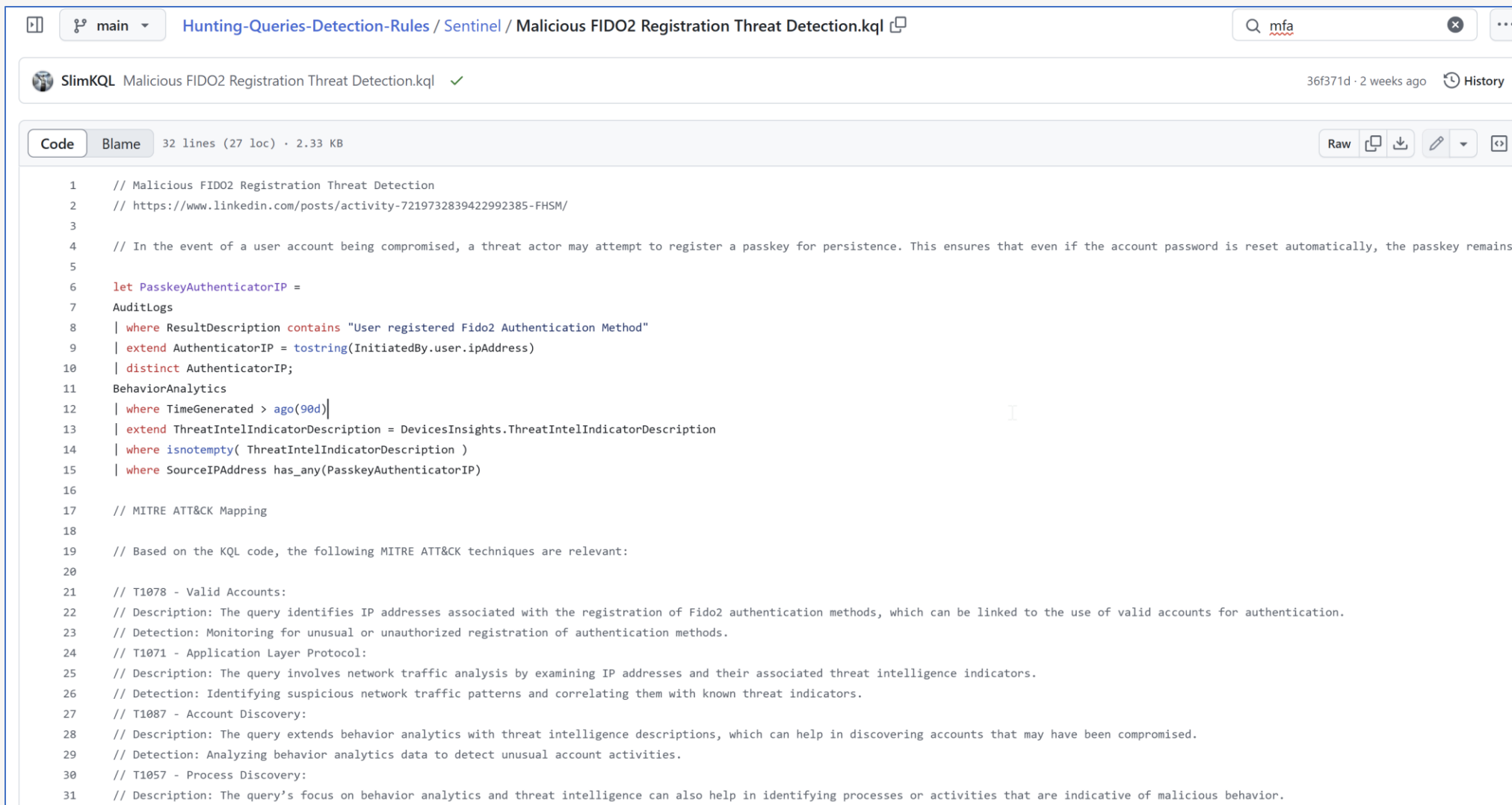
MITRE attack sub-technique

Persistence (TA0003) 

Account Manipulation (T1098) 

N/A

 Expand table



The screenshot shows a web browser interface for a query editor. The address bar displays the URL: `Hunting-Queries-Detection-Rules / Sentinel / Malicious FIDO2 Registration Threat Detection.kql`. A search bar in the top right contains the text `mfa`. Below the address bar, the query name `Malicious FIDO2 Registration Threat Detection.kql` is shown with a green checkmark, along with the identifier `36f371d` and the time `2 weeks ago`. The interface includes tabs for `Code` and `Blame`, and a status bar indicating `32 lines (27 loc) · 2.33 KB`. On the right side of the code editor, there are buttons for `Raw`, `Copy`, `Download`, `Edit`, and `Fullscreen`. The query code is displayed in a light blue background with line numbers from 1 to 31. The code is a SlimKQL query that detects malicious FIDO2 registration threats by analyzing audit logs and threat intelligence indicators. It includes comments explaining the query's purpose and the MITRE ATT&CK techniques it maps to.

```
1 // Malicious FIDO2 Registration Threat Detection
2 // https://www.linkedin.com/posts/activity-7219732839422992385-FHSM/
3
4 // In the event of a user account being compromised, a threat actor may attempt to register a passkey for persistence. This ensures that even if the account password is reset automatically, the passkey remains
5
6 let PasskeyAuthenticatorIP =
7 AuditLogs
8 | where ResultDescription contains "User registered Fido2 Authentication Method"
9 | extend AuthenticatorIP = toString(InitiatedBy.user.ipAddress)
10 | distinct AuthenticatorIP;
11 BehaviorAnalytics
12 | where TimeGenerated > ago(90d)
13 | extend ThreatIntelIndicatorDescription = DevicesInsights.ThreatIntelIndicatorDescription
14 | where isnotempty( ThreatIntelIndicatorDescription )
15 | where SourceIPAddress has_any(PasskeyAuthenticatorIP)
16
17 // MITRE ATT&CK Mapping
18
19 // Based on the KQL code, the following MITRE ATT&CK techniques are relevant:
20
21 // T1078 - Valid Accounts:
22 // Description: The query identifies IP addresses associated with the registration of Fido2 authentication methods, which can be linked to the use of valid accounts for authentication.
23 // Detection: Monitoring for unusual or unauthorized registration of authentication methods.
24 // T1071 - Application Layer Protocol:
25 // Description: The query involves network traffic analysis by examining IP addresses and their associated threat intelligence indicators.
26 // Detection: Identifying suspicious network traffic patterns and correlating them with known threat indicators.
27 // T1087 - Account Discovery:
28 // Description: The query extends behavior analytics with threat intelligence descriptions, which can help in discovering accounts that may have been compromised.
29 // Detection: Analyzing behavior analytics data to detect unusual account activities.
30 // T1057 - Process Discovery:
31 // Description: The query's focus on behavior analytics and threat intelligence can also help in identifying processes or activities that are indicative of malicious behavior.
```

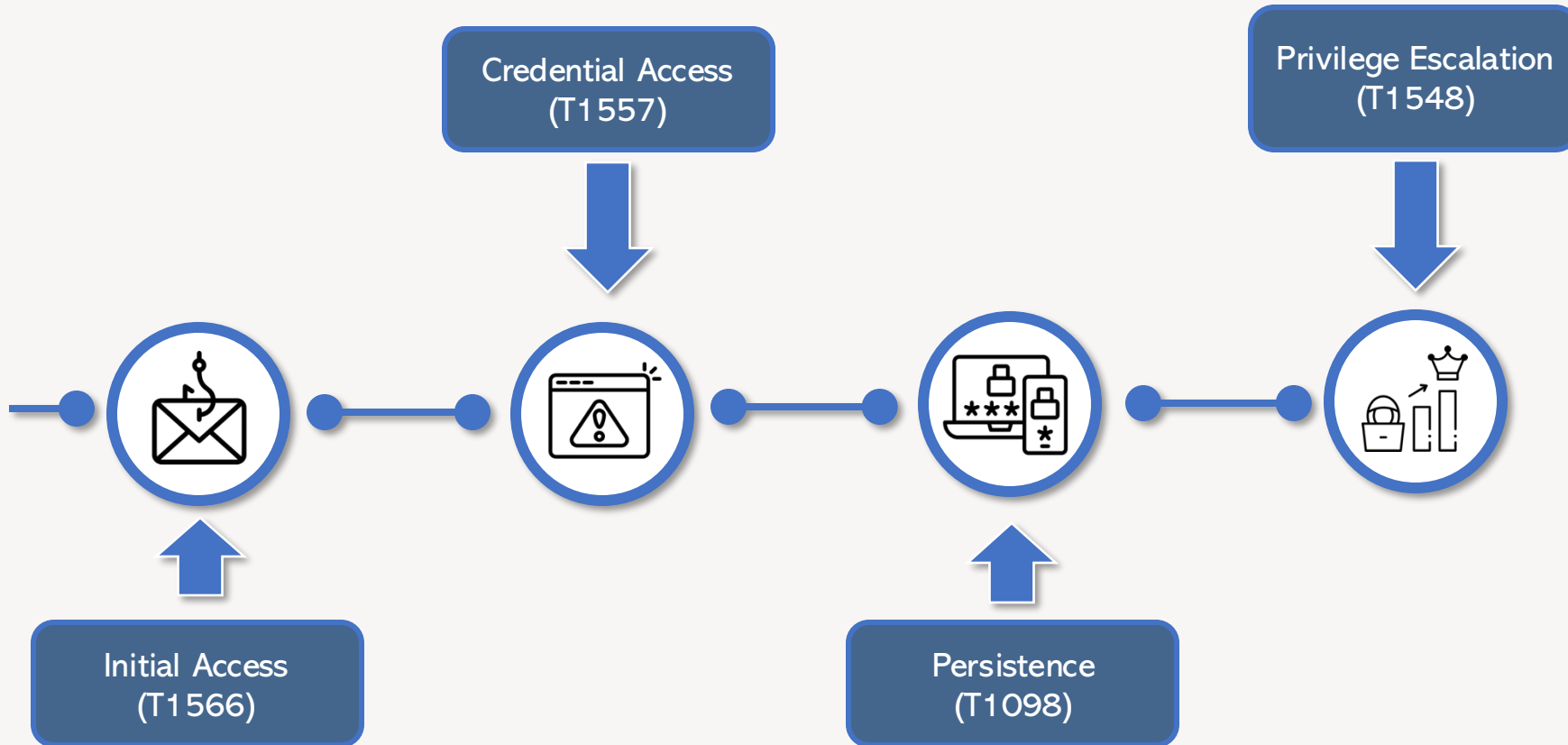


Proactive Threat Hunting

```
1 //Advanced Hunting query to parse modified StrongAuthenticationMethod
2
3 let AuthenticationMethods = dynamic(["TwoWayVoiceMobile","TwoWaySms","TwoWayVoiceOffice","TwoWayVoiceOtherMobile","TwoWaySmsOtherMobile","On
4 let AuthenticationMethodChanges = CloudAppEvents
5 | where ActionType == "Update user." and RawEventData contains "StrongAuthenticationMethod"
6 | extend Target = tostring(RawEventData.ObjectId)
7 | extend Actor = tostring(RawEventData.UserId)
8 | mv-expand ModifiedProperties = parse_json(RawEventData.ModifiedProperties)
9 | where ModifiedProperties.Name == "StrongAuthenticationMethod"
10 | project Timestamp,Actor,Target,ModifiedProperties,RawEventData,ReportId;
11 let OldValues = AuthenticationMethodChanges
12 | extend OldValue = parse_json(tostring(ModifiedProperties.OldValue))
13 | mv-apply OldValue on (extend Old_MethodType=tostring(OldValue.MethodType),Old_Default=tostring(OldValue.Default) | sort by Old_MethodType)
14 let NewValues = AuthenticationMethodChanges
15 | extend NewValue = parse_json(tostring(ModifiedProperties.NewValue))
16 | mv-apply NewValue on (extend New_MethodType=tostring(NewValue.MethodType),New_Default=tostring(NewValue.Default) | sort by New_MethodType)
17 let RemovedMethods = AuthenticationMethodChanges
18 | join kind=inner OldValues on ReportId
19 | join kind=leftouter NewValues on ReportId,$left.Old_MethodType==$right.New_MethodType
20 | project Timestamp,ReportId,ModifiedProperties,Actor,Target,Old_MethodType,New_MethodType
21 | where Old_MethodType != New_MethodType
22 | extend Action = strcat("Removed (", AuthenticationMethods[toint(Old_MethodType)], ") from Authentication Methods.")
23 | extend ChangedValue = "Method Removed";
24 let AddedMethods = AuthenticationMethodChanges
25 | join ki
26 | join ki
27 | project
28 | where 0
29 | extend
30 | extend
31 let Defau
32 | join ki
33 | join ki
34 | where 0
35 | join ki
36 | extend Action = strcat("Default Authentication Method was changed to (", AuthenticationMethods[toint(New_MethodType)], ")")
37 | extend ChangedValue = "Default Method";
38 union RemovedMethods,AddedMethods,DefaultMethodChanges
39 | project Timestamp,Action,Actor,Target,ChangedValue,OldValue=case(isempty(Old_MethodType), "",strcat(Old_MethodType," ", AuthenticationMet
40 | distinct *
```

Timestamp (UTC) ↑	Action	Actor	Target	ChangedValue	OldValue	NewValue
2024-04-16 15:37:56.0000	Added (TwoWayVoiceMobile) as Authentication Method.	Meran@contoso.com	Diego@contoso.com	Method Added		0: TwoWayVoiceMobile
2024-04-16 15:37:56.0000	Added (OneWaySms) as Authentication Method.	Meran@contoso.com	Diego@contoso.com	Method Added		5: OneWaySms
2024-04-16 15:45:06.0000	Default Authentication Method was changed to (OneWaySms).	Meran@contoso.com	Diego@contoso.com	Default Method	6: PhoneAppNotification	5: OneWaySms
2024-04-16 18:07:56.0000	Removed (OneWaySms) from Authentication Methods.	Diego@contoso.com	Diego@contoso.com	Method Removed	5: OneWaySms	
2024-04-16 18:07:56.0000	Removed (TwoWayVoiceMobile) from Authentication Methods.	Diego@contoso.com	Diego@contoso.com	Method Removed	0: TwoWayVoiceMobile	
2024-04-16 18:07:56.0000	Default Authentication Method was changed to (PhoneAppNotification).	Diego@contoso.com	Diego@contoso.com	Default Method	5: OneWaySms	6: PhoneAppNotification

Privilege Escalation / Elevated Access (T1548)



PIM – Authentication Contexts

Global-AuthContext-RequirePasskey

Conditional Access policy

 Delete  View policy information

Control access based on Conditional Access policy to bring signals together, to make decisions, and enforce organizational policies. [Learn more](#)

Name ^{*}

Global-AuthContext-RequirePasskey

Assignments

Users 

0 users and groups selected

Target resources 

1 authentication context included

Network **NEW** 

Not configured

Conditions 

0 conditions selected

Control access based on all or specific network access traffic, cloud apps or actions. [Learn more](#)

Select what this policy applies to

Authentication context

Authentication context is used to secure application data and actions in apps like SharePoint and Microsoft Cloud App Security. [Learn more](#)

Select the authentication contexts this policy will apply to

☒ PIM - Require Passkey

Grant

Control access enforcement to block or grant access. [Learn more](#)

☐ Block access

☒ Grant access

☐ Require multifactor authentication 

 "Require authentication strength" cannot be used with "Require multifactor authentication". [Learn more](#)

☒ Require authentication strength 

Passkeys

PIM – Authentication Contexts

Edit role setting - Security Administrator ...

Privileged Identity Management | Microsoft Entra roles

Activation

Assignment

Notification

Activation maximum duration (hours)

 8

On activation, require

- ☐ None
- ☐ Azure MFA
- ☒ Microsoft Entra Conditional Access authentication context

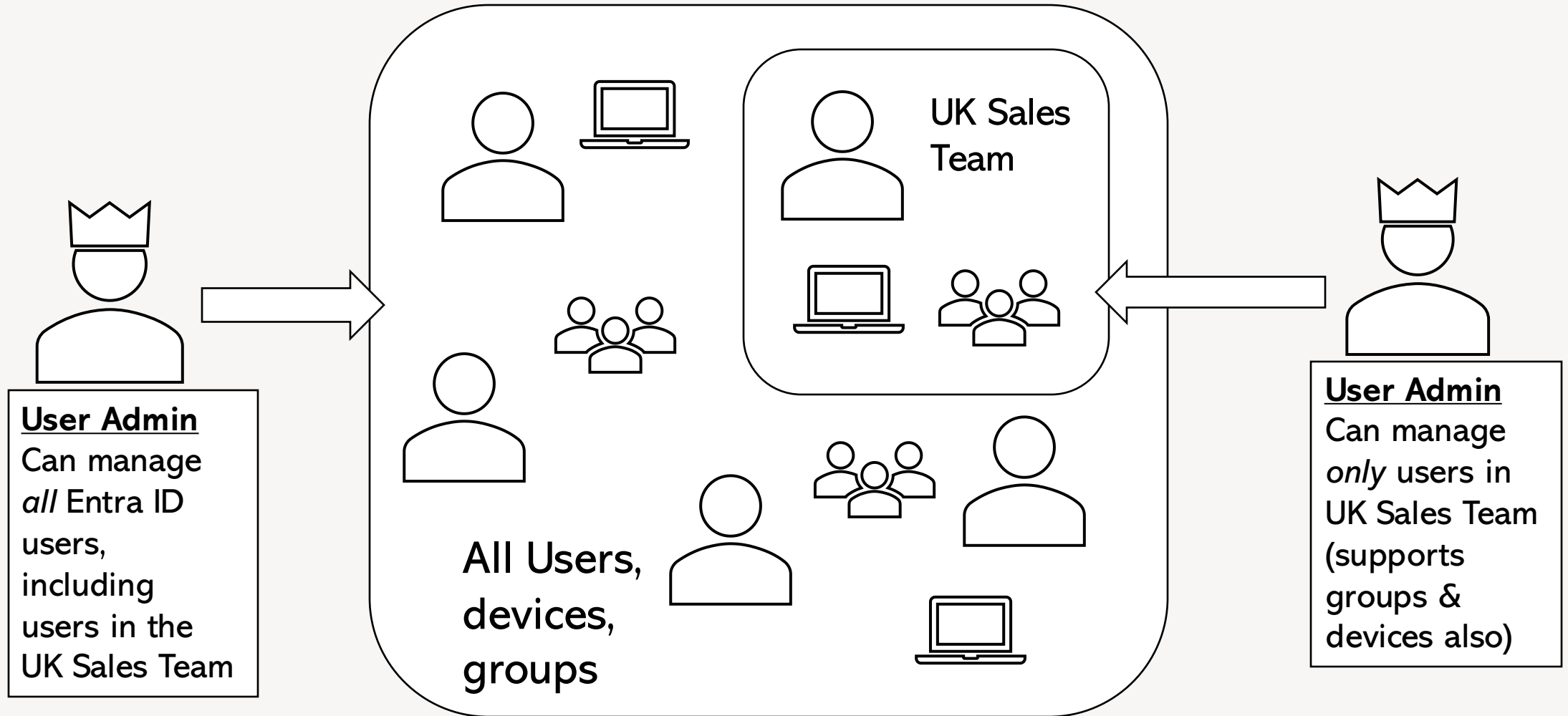
[Learn more](#)

Select 

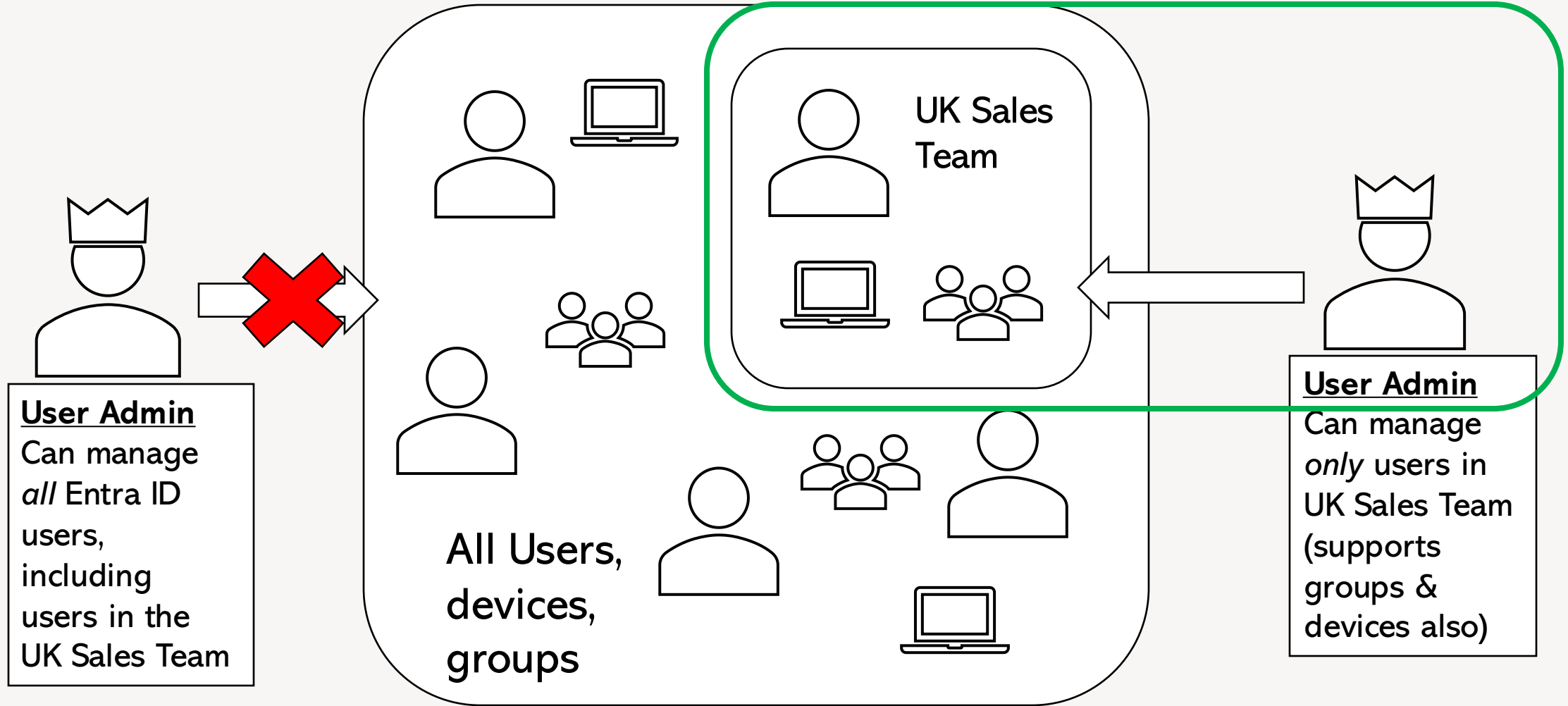
PIM - Require Passkey

- ☒ Require justification on activation
- ☐ Require ticket information on activation
- ☐ Require approval to activate

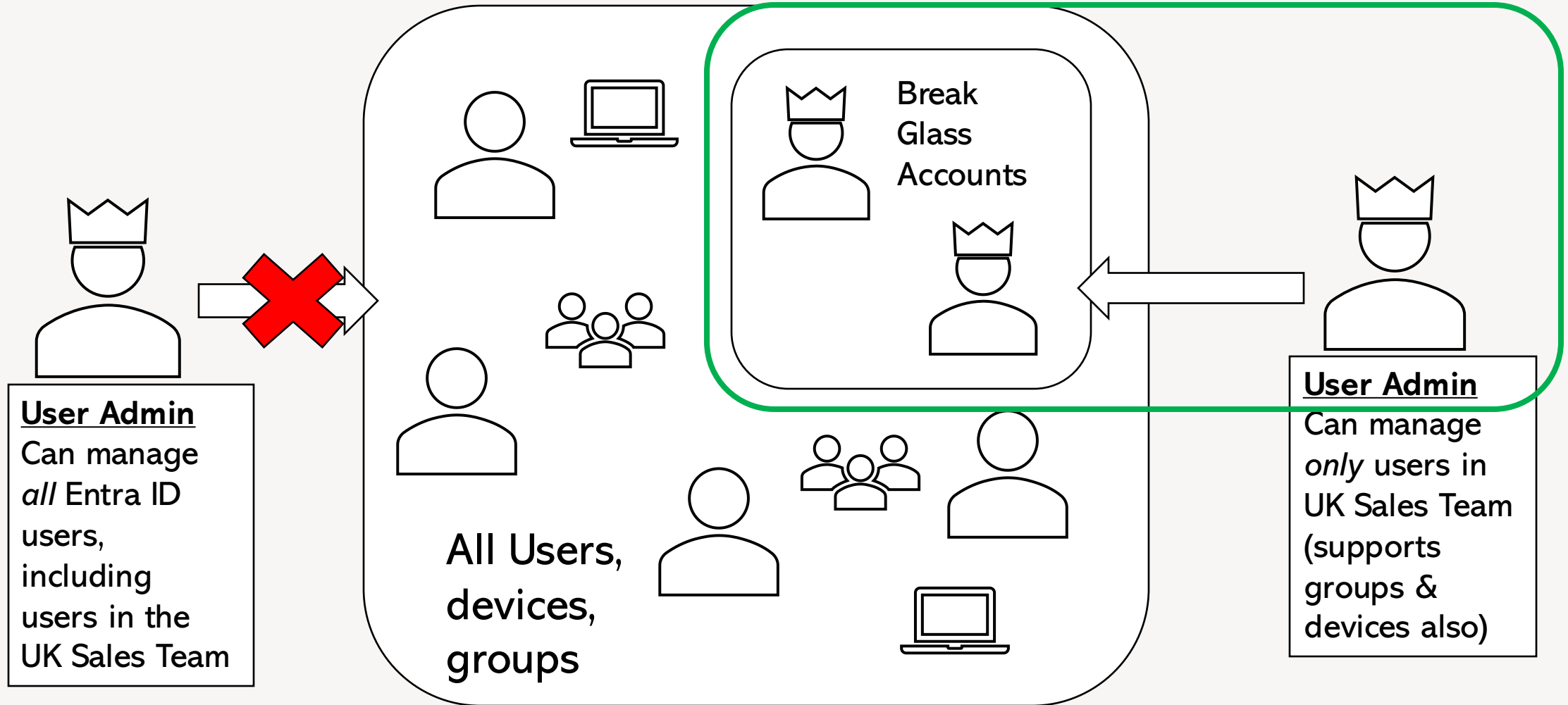
Administrative Units



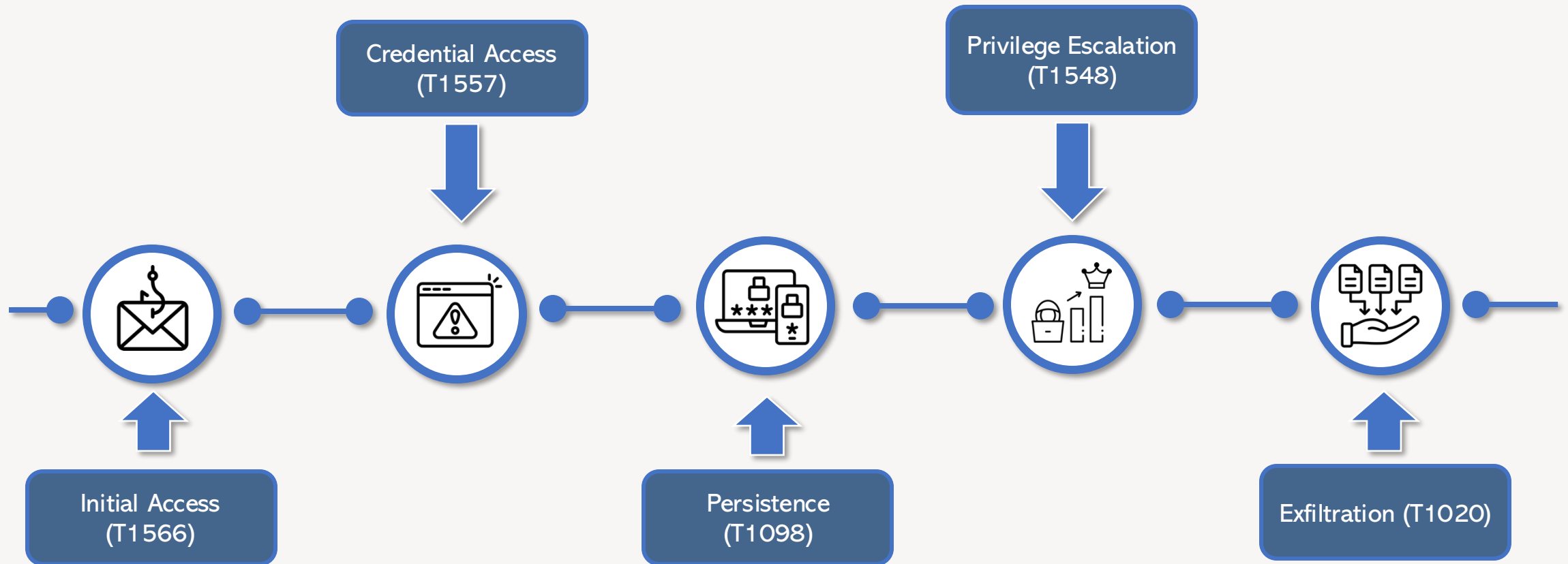
Restricted Management Administrative Units



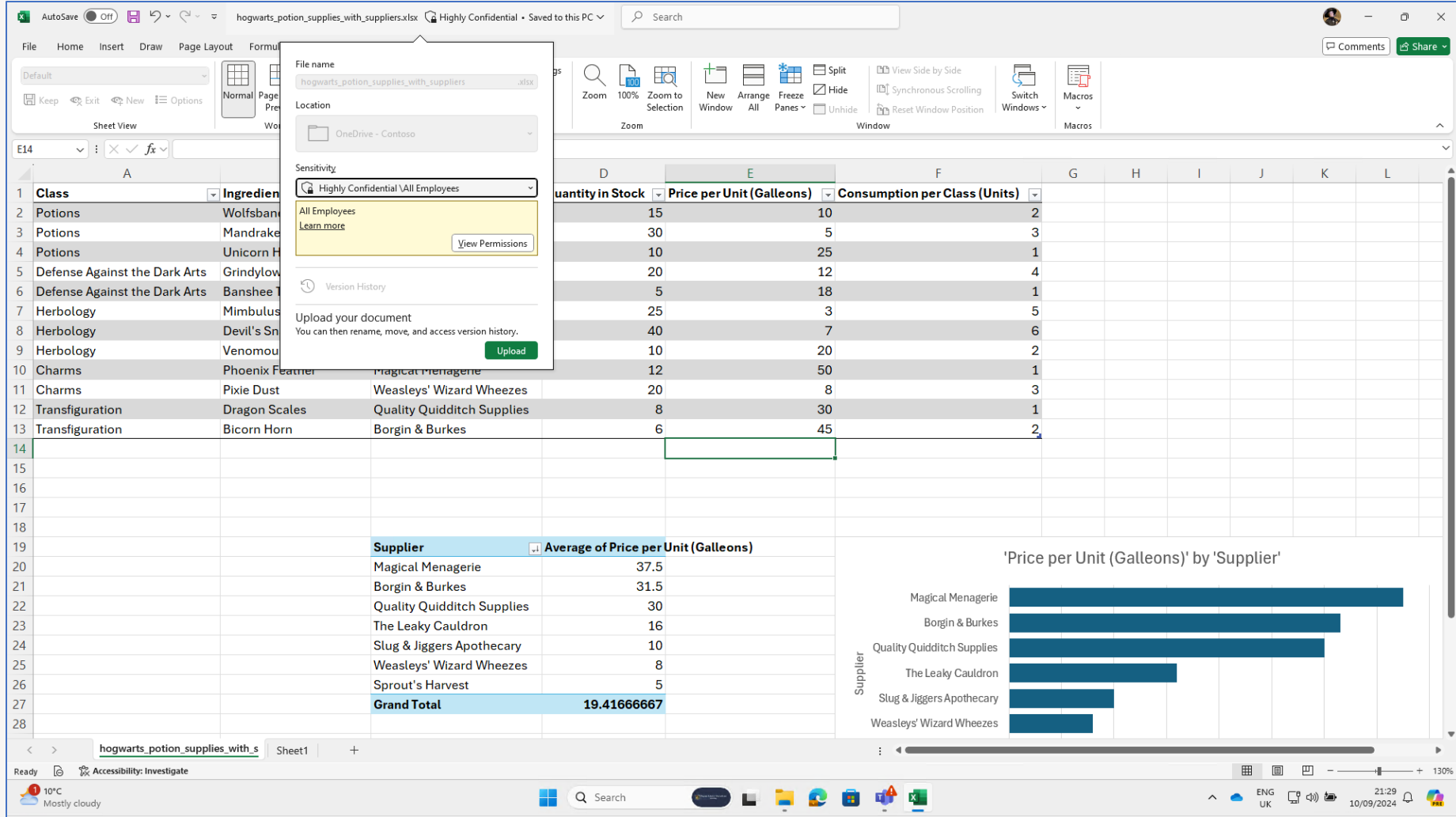
Restricted Management Administrative Units – Use case



Exfiltration / Automated Exfiltration (T1020)



Sensitivity Labels



The screenshot displays a Microsoft Excel spreadsheet titled "hogwarts_potion_supplies_with_suppliers.xlsx". A sensitivity label dialog box is open, showing the file name "hogwarts_potion_supplies_with_suppliers.xlsx" and the location "OneDrive - Contoso". The sensitivity level is set to "Highly Confidential \All Employees". The dialog box also includes a "Version History" section and an "Upload" button.

The spreadsheet contains a table with the following data:

Class	Ingredient	Quantity in Stock	Price per Unit (Galleons)	Consumption per Class (Units)
Potions	Wolfsbane	15	10	2
Potions	Mandrake	30	5	3
Potions	Unicorn Hair	10	25	1
Defense Against the Dark Arts	Grindylow	20	12	4
Defense Against the Dark Arts	Banshee Tail	5	18	1
Herbology	Mimbulus	25	3	5
Herbology	Devil's Snail	40	7	6
Herbology	Venomous Fang	10	20	2
Charms	Phoenix Feather	12	50	1
Charms	Pixie Dust	20	8	3
Transfiguration	Dragon Scales	8	30	1
Transfiguration	Bicorn Horn	6	45	2

Below the main table, there is a summary table showing the average price per unit for each supplier:

Supplier	Average of Price per Unit (Galleons)
Magical Menagerie	37.5
Borgin & Burkes	31.5
Quality Quidditch Supplies	30
The Leaky Cauldron	16
Slug & Jiggers Apothecary	10
Weasleys' Wizard Wheezes	8
Sprout's Harvest	5
Grand Total	19.41666667

A horizontal bar chart titled "Price per Unit (Galleons)" by "Supplier" is also displayed, showing the average price per unit for each supplier. The chart uses blue bars to represent the data.

Sensitivity Labels

Access control

Use encryption capabilities to control who can access labeled items. Depending on the scope you specified, items can include emails, Office, Fabric and Power BI files, and meeting invites. [Learn more about access control settings](#)

- ☐ Remove access control settings if already applied to items
- ☒ Configure access control settings

Assign permissions now or let users decide?

Assign permissions now

The settings you choose will be automatically enforced when the label is applied to email and Office files.

User access to content expires ⓘ

Never

Allow offline access ⓘ

Always

Assign permissions to specific users and groups * ⓘ

[Assign permissions](#)

Assign permissions to specific users and groups * ⓘ

[Assign permissions](#)

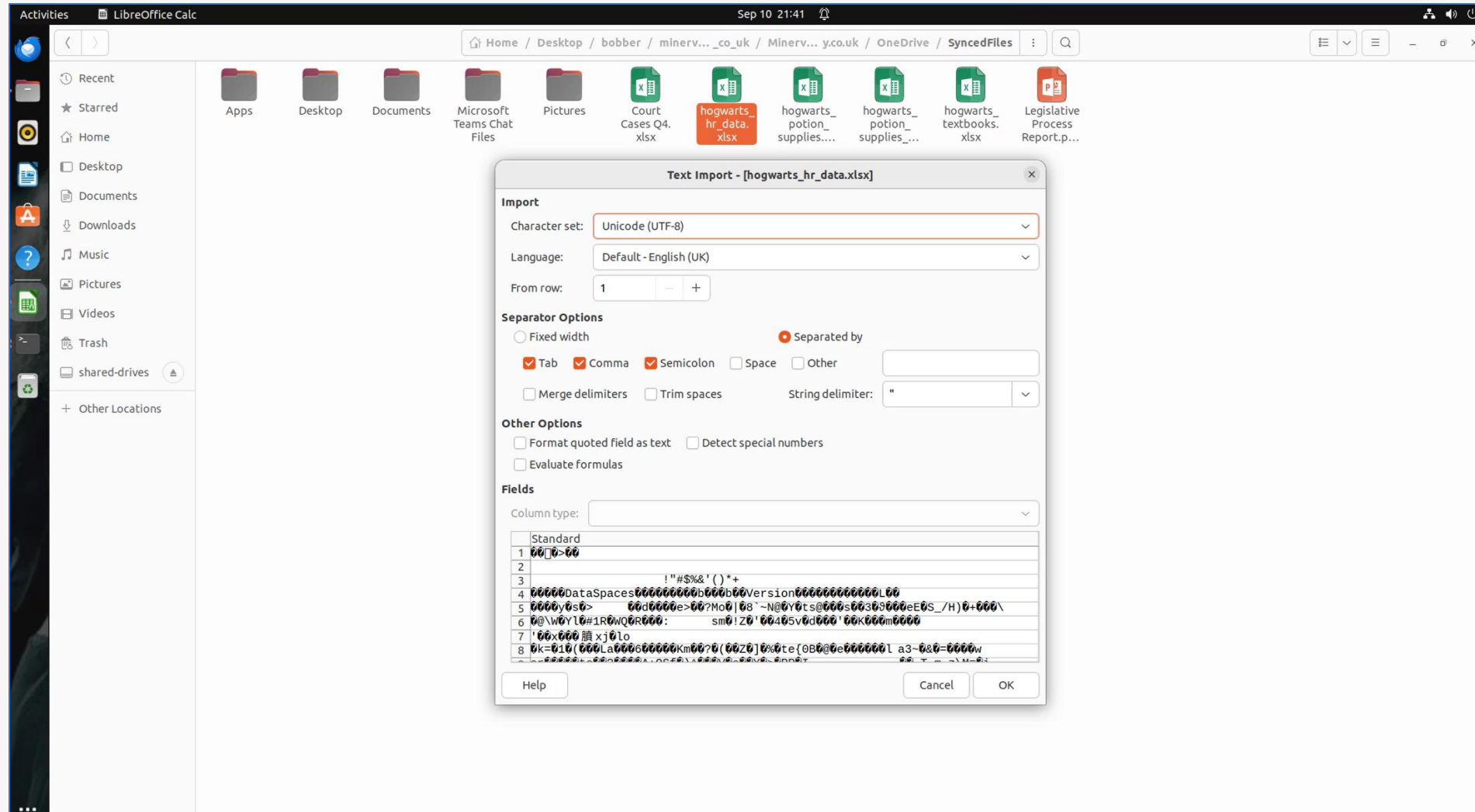
2 items

Users and groups	Permissions	Edit	Delete
M365x25307416.onmicrosoft.com	Co-Author		
hogwartsschoolofwitchcraftandwizardry.co.uk	Co-Author		

☒ Use dynamic watermarking ⓘ

☐ Use Double Key Encryption ⓘ

Sensitivity Labels



Sensitivity Labels

New sensitivity label

- ✓ Label details
- ✓ Scope
- ✓ Items
- **Groups & sites**
- **External sharing & conditional access**
- Schematized data assets (preview)
- Finish

Define external sharing and conditional access settings

Control who can share SharePoint content with people outside your organization and decide whether users can access labeled sites from unmanaged devices.

☐ **Control external sharing from labeled SharePoint sites**

When this label is applied to a SharePoint site, these settings will replace existing external sharing settings configured for the site.

☒ **Use Microsoft Entra Conditional Access to protect labeled SharePoint sites**

You can either control the level of access users have from unmanaged devices or select an existing authentication context to enforce restrictions.

- ☒ Determine whether users can access SharePoint sites from unmanaged devices (which are devices that aren't [Microsoft Entra hybrid joined](#) or enrolled in Intune).

i For this setting to work, you must also configure the SharePoint feature that blocks or limits access to SharePoint files from unmanaged devices. [Learn more](#)

- ☒ Allow full access from desktop apps, mobile apps, and the web

- ☐ Allow limited, web-only access *i*

- ☐ Block access *i*

- ☐ Choose an existing authentication context. Each context has an Microsoft Entra Conditional Access policy applied to enforce restrictions. [Learn more about authentication context](#)

i There aren't any authentication contexts configured in your organization. [Learn how to create one](#)

No authentication contexts set up yet

Data Loss Prevention

Data loss prevention > Create policy

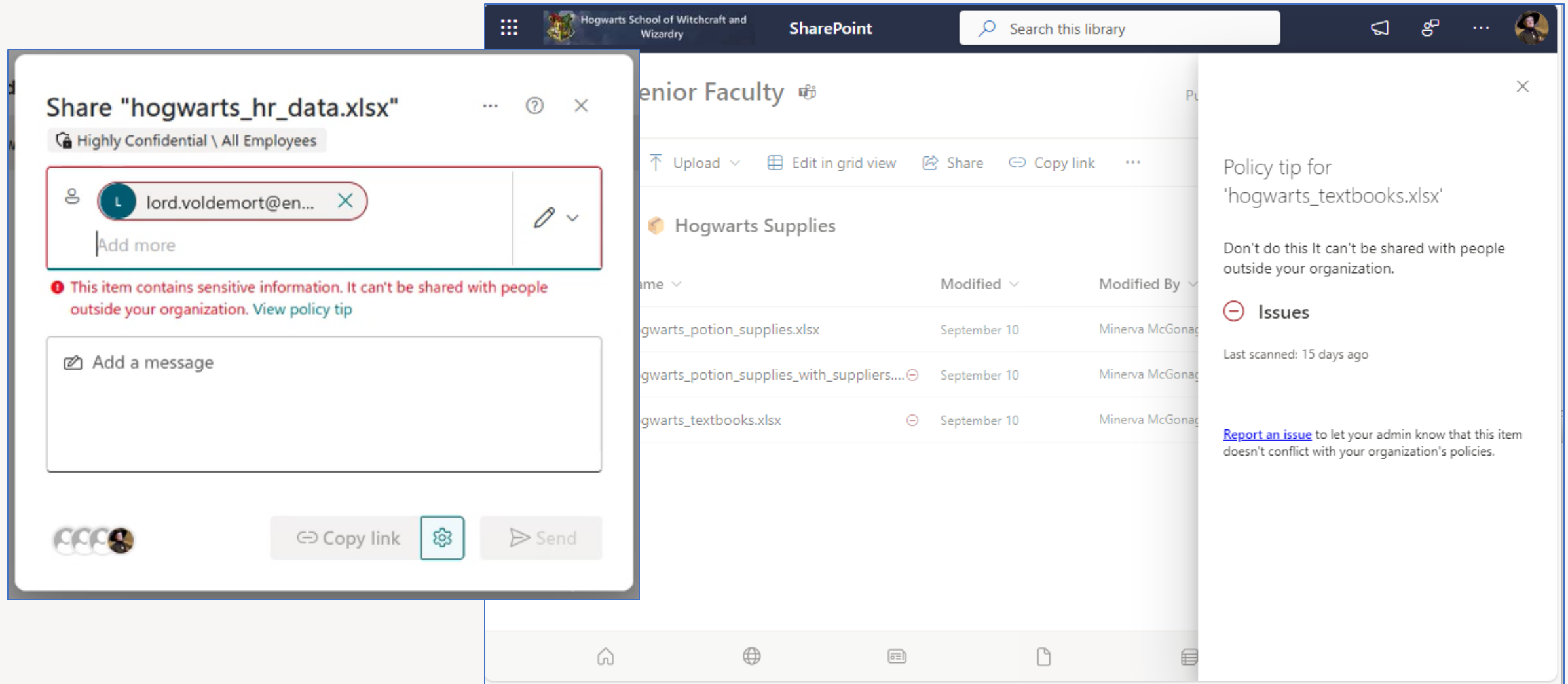
- ✓ Template or custom policy
- ✓ Name
- ✓ Admin units
- ✓ Locations
- **Policy settings**
- Advanced DLP rules

+ Create rule

1 item

Name	Status	
 SPO / External recipient / Highly Confidential data / Block	☒ On	
Conditions Content is shared from Microsoft 365 with people outside my organization		
And		
Content contains any of these sensitivity labels: Highly Confidential, Highly Confidential/All Employees		
Evaluate predicate for Message or attachment		
Actions Restrict access to the content for external users Send alerts to Administrator		

Data Loss Prevention



The screenshot displays a SharePoint interface for the 'Hogwarts School of Witchcraft and Wizardry' library. A share dialog for 'hogwarts_hr_data.xlsx' is open, showing a security warning: 'This item contains sensitive information. It can't be shared with people outside your organization. View policy tip'. The warning is highlighted with a red box. The share list includes 'lord.voldemort@en...' and an 'Add more' button. The dialog also features a 'Copy link' button and a 'Send' button. In the background, a table titled 'Hogwarts Supplies' lists files: 'hogwarts_potion_supplies.xlsx', 'hogwarts_potion_supplies_with_suppliers....', and 'hogwarts_textbooks.xlsx'. A policy tip for 'hogwarts_textbooks.xlsx' is also visible, stating: 'Don't do this It can't be shared with people outside your organization.' and 'Issues Last scanned: 15 days ago'. A link to 'Report an issue' is provided.

Share "hogwarts_hr_data.xlsx"

Highly Confidential \ All Employees

lord.voldemort@en... X

Add more

This item contains sensitive information. It can't be shared with people outside your organization. View policy tip

Add a message

Copy link

Send

Senior Faculty

Upload Edit in grid view Share Copy link

Hogwarts Supplies

Name	Modified	Modified By
hogwarts_potion_supplies.xlsx	September 10	Minerva McGonagall
hogwarts_potion_supplies_with_suppliers....	September 10	Minerva McGonagall
hogwarts_textbooks.xlsx	September 10	Minerva McGonagall

Policy tip for 'hogwarts_textbooks.xlsx'

Don't do this It can't be shared with people outside your organization.

Issues

Last scanned: 15 days ago

[Report an issue](#) to let your admin know that this item doesn't conflict with your organization's policies.

Defender for Cloud Apps

Incidents > Multi-stage incident involving one user reported by multiple sources

Multi-stage incident involving one user reported by multiple sources

Manage incident Activity log

High Active Unassigned

Attack story Alerts (5) Assets (3) Investigations (0) Evidence and Response (2) Summary

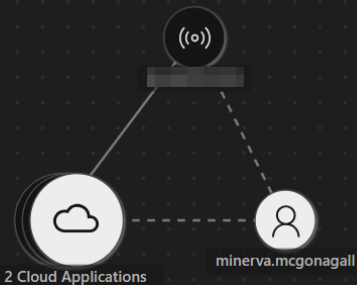
Alerts

Play attack story Unpin all Show all

- Oct 2, 2024 10:16 PM New
User compromised through session cookie hijack
Minerva McGonagall
- Oct 2, 2024 10:21 PM New
SS24 - Mass download by a single user (2)
Minerva McGonagall
- Oct 2, 2024 10:21 PM New
SS24 - Mass download by a single user (2)
Minerva McGonagall
- Oct 2, 2024 10:21 PM New
SS24 - Mass download by a single user (2)
Minerva McGonagall
- Oct 2, 2024 10:21 PM New
SS24 - Mass download by a single user (2)
Minerva McGonagall

Incident graph

Layout Group similar nodes



```
graph TD; A(( )) --- B((cloud)); A -.- C((minerva.mcgonagall)); B -.- C;
```

2 Cloud Applications minerva.mcgonagall

Incident details

Assigned to Unassigned Incident ID 23

Classification Not set Categories Credential access, Suspicious activity

First activity Oct 2, 2024 10:16:05 PM Last activity Oct 2, 2024 10:21:19 PM

Impacted assets

Users (1)

Minerva McGonagall

Apps (2)	Application ID	Risk
Microsoft ...	15600	None
Microsoft ...	20892	None

Defender for Cloud Apps

Create activity policy

Policy template *

Mass download by a single user

Policy name *

Mass download by a single user

Policy severity *



Category *

Threat detection

Description

Alert when a single user performs more than 50 downloads within 1 minute.

Create filters for the policy

Act on:



Single activity

Every activity that matches the filters



Repeated activity:

Repeated activity by a single user

Minimum repeated activities:

50

Within timeframe:

1

minutes



In a single app



Count only unique target files or folders per user ⓘ

Governance actions



All apps



Notify user ⓘ



Notify additional users ⓘ



Suspend Microsoft Entra user ⓘ
For Microsoft Entra users



Require user to sign in again ⓘ
For Microsoft Entra users



Confirm user compromised ⓘ
For Microsoft Entra users



Microsoft 365



Suspend user in app



Require user to sign in again



Confirm user compromised

And everything else...

Windows Enrollment Attestation

Tenant Restrictions v2

Safe Attachments

Insider Risk Management

SPF / DKIM / DMARC

Active Directory / Entra ID tiering

Device Hardening

Restrict Device Code Flow

Credential Guard

AppLocker / WDAC

SmartScreen

Oauth Consent / Compromise

Tenant Allow / Block Lists (TLDs)

Attack Surface Reduction Rules

Ingest into a SIEM (Sentinel)

Web Content Filtering (Newly Registered Domains)

Edge Hardening

Information Barriers

Platform SSO (macOS)

[Cloud-Architekt/AzureAD-Attack-Defense: This publication is a collection of various common attack scenarios on Microsoft Entra ID \(formerly known as Azure Active Directory\) and how they can be mitigated or detected.](#)

[Protecting Tokens in Microsoft Entra ID - Microsoft Entra ID | Microsoft Learn](#)

[Token theft playbook | Microsoft Learn](#)

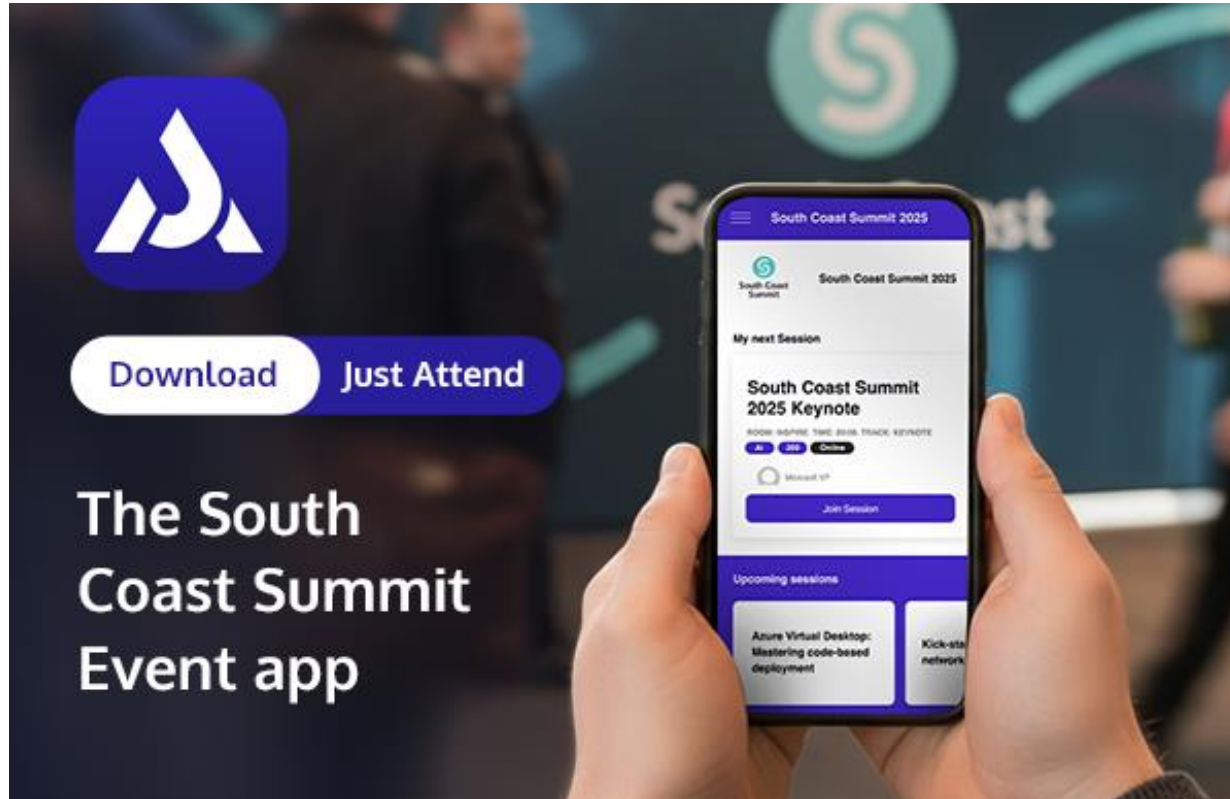
[jkerai1/So-You-ve-Got-MFA-Defending-and-Responding-Against-MFA-Bypass-Techniques-in-Entra: Slides presented at <https://www.meetup.com/m365sandcug/events/302644214>](#)

[How Hackers Bypass MFA? \[2 Ways To Stop Them\]](#)

[How to stop AiTM token phishing in Microsoft 365](#)

[Blog Posts | Welka's World](#)

FEEDBACK



SOUTH COAST SUMMIT
A CLOUD TECHNOLOGY COMMUNITY CONFERENCE

#SCS2025

